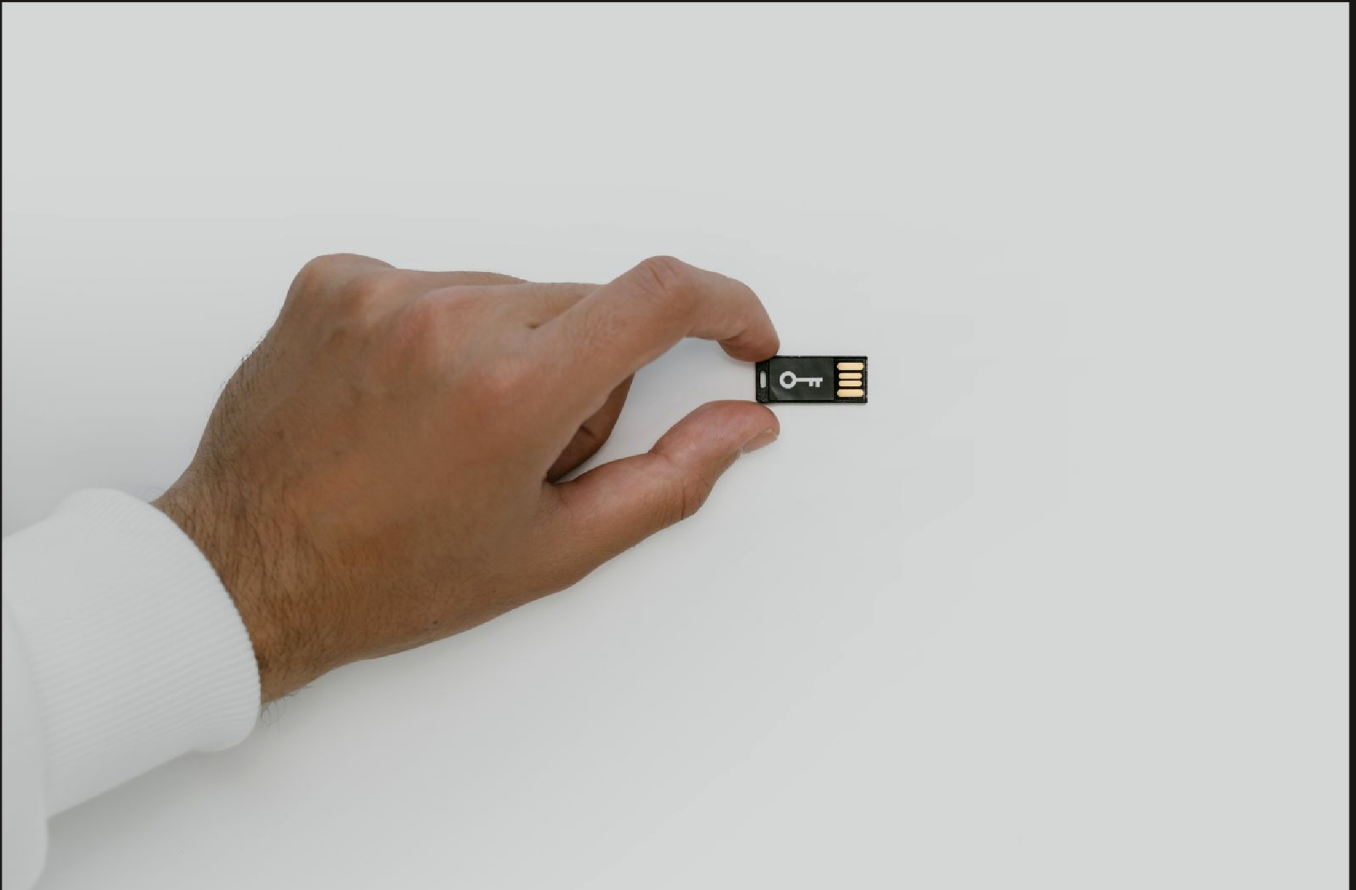


A SPECIAL EDITION OF

MERIDIAN

Home cybersecurity — an ultra deep dive



A hardware security key, seated — the one purchase in this book every desk agrees on. Representative image.

THE GEAR

A buy-once-cry-once ladder from a \$58 key to a \$899 firewall appliance — and the OpenAI partnership that just made hardware keys mandatory, not optional, for the first time

THE SCEPTIC

Which half of the home-security market is theatre, argued by the people who'd normally be selling it to you

THE LONG READ

A government sends its own citizens simulated scam calls on purpose — inside the country that just folded fraud into its Cold War defence doctrine

THIS SPECIAL

Home Cybersecurity — Contents

p3–4 The Invitation — who actually attacks a home in 2026, restated honestly: the real numbers behind the scare headlines, and the one social-engineering trick behind most of them

p5–6 The Desktop Perimeter — Windows 11 hardening: Defender vs. paid suites, BitLocker's silent escrow, and the just-in-time admin model that just replaced twenty years of standard-account advice

p7–8 The WSL2 Seam — what Linux-inside-Windows actually isolates, the file-permission crossover that confuses everyone, and the update command that didn't patch what it claimed to

p9–10 The Other Half of the House — macOS hardening: Gatekeeper's real job, FileVault's rewritten recovery model, and a summer of infostealers with a very consistent playbook

p11–12 Identity as the Perimeter — passkeys, phishing-resistant MFA, and the password manager landscape four years into LastPass's still-unfolding aftermath

p13–14 The Network Layer — router CVEs by brand, DNS filtering honestly scoped, VLANs versus a Matter/Thread household's real limits, and Tailscale over port-forwarding

p15–16 The Last Line — backups as the failure-mode that actually matters: 3-2-1-1-0, immutable NAS snapshots, and the restore nobody tested until it was too late

p17–19 The Gear — the buy-once-cry-once ladder in full: keys, appliances, NAS, and the custom/self-hosted tier, plus what genuinely changed in the last twelve months

p20 The Family Desk — securing an 11-year-old's first devices without surveillance theatre

p21–22 The Community — the subreddits, the practitioner culture, and the gap between what security professionals sell and what they run at home

p23 The Sceptic — the hardest cross-examination in the book: half of home security spending is theatre, argued plainly

p24–25 The Fresh-Peg Sweep — the incidents still landing as this book closes, including the one aimed squarely at this reader's own AI lab

p26–27 The Long Read — "The Robocall Drill"

FROM THE DESK

"Security is a process, not a product."

— Bruce Schneier, "The Process of Security," Crypto-Gram newsletter, 15 May 2000¹

Schneier wrote this at the height of the box-store era, when a firewall and an antivirus CD felt like a finished purchase. Twenty-six years on, replace "network" with "household" and the sentence hasn't aged a day — this book is about the process, not the product, even where it spends three pages recommending products.²

HOME CYBERSECURITY — AT A GLANCE

METRIC	FIGURE
Breaches now led by unpatched software, not stolen creds	31% (2026)
Median time to patch a known flaw	43 days, up from 32
Malicious VS Code extensions found, 2024 → 2025	27 → 105
Phishing-resistant MFA blocking identity attacks	99%+
A real entry-tier hardware security key	US\$29–58
A buy-once-cry-once home firewall appliance	US\$479–899

Figures as researched for this edition, Aug 2026; see the sections named for full sourcing.³

WHY THIS SPECIAL EXISTS

This edition was commissioned directly — a reader request routed through a Claude Code session, not the ↗ button on a daily article, so there is no prior Rabbit Hole treatment to assume as read.⁴ The brief stays specific throughout: a real HOME, not an enterprise fleet — Windows 11 desktops (including a GPU workstation for local AI work), WSL2 Ubuntu on those machines, macOS laptops, no IT department. Defensive only: hardening, hygiene and recovery — never offensive tooling.

SOURCES 1 Bruce Schneier, "The Process of Security," Crypto-Gram newsletter, 15 May 2000; reprinted in *Secrets and Lies* (2000). 2 Editorial framing, this edition. 3 Figures researched Aug 2026; see named sections for full sourcing — several rest on vendor-aggregated or search-summarized secondary reporting and are flagged as such in place. 4 Reader note, feedback log, 14 Aug 2026 01:10 UTC ("SPECIAL EDITION REQUEST: Home cybersecurity...").

A NEW COMMISSION

The Invitation

Not a fortress brief. A real household — two operating systems, a Linux subsystem, no IT department — and the honest, current answer to the only question that matters: who actually comes for a home in 2026, and how.

this story 

Start with the number that reframes everything else in this book. For the first time, exploiting an unpatched piece of software has overtaken stolen credentials as the leading way into a breach — 31 percent of confirmed intrusions in 2026, per Verizon's Data Breach Investigations Report, edging past a credential-led breach mix that had dominated for years.¹ The reason isn't that software got worse. It's that patching got slower: median time-to-patch a known flaw rose from 32 to 43 days year over year, and only 26 percent of vulnerabilities on CISA's own Known Exploited list were fully remediated in 2025, down from 38 percent the year before.² Read plainly: the gap between "a fix exists" and "the fix is installed" is the actual attack surface, on a home PC as much as a data centre.

Who walks through that gap, for a household with no enterprise security team? Overwhelmingly, not a nation-state. It's infostealer malware — commodity credential-and-cookie thieves distributed through cracked software, game cheats and mods, and search-engine-poisoned download pages, the same handful of families (Lumma, StealC, Vidar, RedLine's successors) cycling through takedowns and resurgences.³ One coalition-led takedown in May 2025 seized over 2,300 domains tied to Lumma Stealer, which had compromised 394,000 Windows systems in the prior three months alone — and new infrastructure was back within days, fully recovered to prior volume within two months.⁴ Verizon's own data makes the home-relevance explicit: 46 percent of infostealer-compromised systems in 2025 were unmanaged or bring-your-own devices — not a corporate laptop with an agent watching it, but

exactly the kind of machine on the desk this book is about.⁵

31%

SHARE OF 2026 BREACHES NOW LED BY EXPLOITING
UNPATCHED SOFTWARE — FOR THE FIRST TIME AHEAD OF
STOLEN CREDENTIALS¹

Almost every named incident in this book's research shares one delivery mechanism, and it is worth naming on page one because it recurs on page after page that follows: **ClickFix**. A compromised or malicious page shows a fake CAPTCHA or a fake "your document failed to load" error, and a script quietly copies a command to the clipboard; the victim is told to open Run or Terminal and paste it to "verify" or "fix" the problem. Nothing was downloaded, so nothing was scanned — the user executed the payload themselves. On Windows in 2025 it made up more than a third of all non-malware security alerts flagged to the US government's own monitoring network; on macOS it is now the dominant delivery method for the summer's infostealer wave (p9); and in March 2026 it was the exact technique behind Google-Ads malvertising impersonating Anthropic's own Claude Code, complete with a fake "Sponsored" documentation page, targeting the precise reader profile this book is written for.⁶

If a page ever asks you to copy a command and paste it into Run or Terminal to prove you're human, that is the attack, full stop.

SOURCES ¹ Verizon 2026 Data Breach Investigations Report, [verizon.com/business/resources/reports/dbir](https://www.verizon.com/business/resources/reports/dbir), summarized via Tenable Connect and HelpNetSecurity coverage, May 2026. ² Same DBIR 2026 dataset; CISA Known Exploited Vulnerabilities remediation rate per DBIR 2026 analysis. ³ Verizon 2025 DBIR ([verizon.com/about/news/2025-data-breach-investigations-report](https://www.verizon.com/about/news/2025-data-breach-investigations-report)); 37% YoY rise in combined ransomware+infostealer incidents. ⁴ Lumma Stealer takedown, Microsoft DCU/FBI/Europol coalition, May 2025 — BankInfoSecurity, Trend Micro Research; resurgence confirmed by Bitdefender, Feb 2026. ⁵ Verizon 2025 DBIR, unmanaged/BYOD share of infostealer-compromised systems. ⁶ Microsoft Security Blog, "Think Before You ClickFix," 21 Aug 2025; Bitdefender Labs, "fake Claude Code" Google Ads campaign, reported ~March 2026 via MI-3 and SecurityOnline.

The front door isn't the only place attackers now knock. As passkeys and hardware keys close off the credential-phishing route (p11), Microsoft's own researchers describe attackers shifting toward the softer target next to it — account-recovery flows, "verify your identity" re-authentication prompts, and AI-generated impersonation, rather than the login form itself.¹ Singapore supplies the starkest illustration on record: in 2026 a local finance director authorised a US\$499,000 wire transfer after a video call in which every other participant — a company director, several colleagues — was an AI-generated deepfake, prompting a joint Police Force, Monetary Authority and Cyber Security Agency advisory on AI voice-and-video impersonation.² The identity layer isn't a side desk in this book; it's load-bearing.

SIM-swapping tells the same story from a different angle. The UK recorded roughly 3,000 unauthorised SIM swaps in 2024 — a year-over-year jump Cifas, the UK's fraud-prevention body, called a 1,055 percent surge — and, tellingly, victims aged 61 and over went from a small share to 29 percent of all UK account-takeover cases, up 90 percent in a single

year.³ That is the dinner-party fact this book opens with: the emerging SIM-swap victim isn't a crypto trader with a hardware wallet, it's someone's retired parent, targeted precisely because their accounts still lean on a phone number as the last line of defence.

+1,055%

YEAR-OVER-YEAR RISE IN UNAUTHORISED SIM SWAPS FILED TO THE UK'S NATIONAL FRAUD DATABASE, 2024³

From here the book runs outward, desk by desk, in the order a real household would actually harden itself: the Desktop Perimeter (p5) and the WSL2 Seam (p7) it sits on, then the Other Half of the House (p9) for the Mac side of a mixed household, Identity (p11), the Network Layer (p13) that carries all of it, the Last Line of backups (p15), then the Gear worth actually buying (p17), the Family Desk (p20), the Community that argues about all of the above daily (p21), the Sceptic making the case against half of what came before (p23), the incidents still landing as this book goes to print (p24), and a Long Read into the one country running scam civil-defence drills on its own population by design (p26).

WHAT MICROSOFT'S OWN TELEMETRY SAYS

Microsoft's Digital Defense Report, released January 2026, puts a number on the identity side of this picture: identity-based attacks rose 32 percent in the first half of 2025, and more than 97 percent of them are large-scale password-guessing and spraying — brute-force arithmetic, not sophisticated intrusion. The same report's headline defensive number: phishing-resistant multi-factor authentication, meaning passkeys and hardware keys rather than a six-digit code, blocks more than 99 percent of these attacks outright.⁴ That single statistic does more editorial work in this book than any other — it is why Identity as the Perimeter (p11) is the section that follows the network and desktop chapters rather than trailing behind them.

THE SCEPTIC, EARLY

Not every number in this genre is as solid as its headline suggests. Vendor-sourced aggregate figures — "26 billion credential-stuffing attempts a month," "1.8 billion stolen credentials in 2025" — circulate widely with no single shared methodology behind them, and this book treats them as directional, not precise, flagging each one in place rather than repeating them as settled fact.⁵ And the picture isn't uniformly worse everywhere: Singapore's own 2025 scam-and-cybercrime tally actually FELL 27.6 percent year over year even as the median loss per victim rose — fewer people caught, each one hit harder (p26). Home-security journalism's habit of only ever reporting the number that goes up is itself worth a sceptical eyebrow.⁶

SOURCES 1 The Hacker News, "The Verification Step Is the New ATO Battleground in 2026," Jul 2026. 2 Singapore Police Force / Monetary Authority of Singapore / Cyber Security Agency joint advisory on AI voice-and-video impersonation scams, 2026; reported via multiple SPF advisory releases, see p26–27 sourcing. 3 Efani, "SIM Swap Fraud Statistics 2026," citing UK Cifas National Fraud Database figures. 4 Microsoft Digital Defense Report 2025, released 7 Jan 2026 (news.microsoft.com/source/asia). 5 DeepStrike and SecureW2 aggregation blogs, credential-stuffing volume estimates, 2026 — vendor-sourced, flagged as directional. 6 SPF Police Life, "Scams and Cybercrime Fell by Almost a Quarter in 2025," Feb 2026; SPF Annual Scam and Cybercrime Brief 2025.

WINDOWS 11, 2026

The Desktop Perimeter

The antivirus question is nearly settled. The real 2026 story is a quiet redesign of what "administrator" even means — and a GPU workstation full of unsigned, self-built AI tooling is exactly the machine that redesign was built for.

this story 

Is Microsoft Defender enough on its own in 2026? The independent labs say, with real confidence, yes. AV-TEST's rolling home-Windows results through the year show Defender scoring a perfect 18/18 in several rounds and matching the paid field — Bitdefender, Kaspersky, Norton, McAfee among them — at the top of the table rather than trailing it.¹ AV-Comparatives' March 2026 Malware Protection Test put Defender at 18/18 with a 99.89 percent real-world protection rate against Bitdefender's 99.97 — a gap the lab itself describes as roughly eight extra misses per ten thousand samples, "statistically negligible" for a typical home user's exposure.² The honest case for a paid suite in 2026 has moved away from "catches more malware" — the labs no longer really support that claim — toward the bundle: identity monitoring, a VPN, a password manager, cross-platform coverage. Whether that bundle is worth paying for on its own terms is a Sceptic-desk question (p23), not an antivirus one.

BitLocker's real 2026 wrinkle isn't the encryption — it's the recovery key. Windows 11 Home ships "Device Encryption," which is the same technology as full

BitLocker running on autopilot: on qualifying hardware it can switch itself on the moment you sign in with a Microsoft account, silently escrowing the recovery key to that account without a dialogue box announcing it.³ Two failure modes follow from that, both real and both avoidable: not knowing the key was ever generated, and losing access to the very Microsoft account that holds it. Microsoft is explicit that it cannot recover a lost key — a locked-out machine may mean a full reset. The practical fix costs thirty seconds: open Settings → Privacy & security → Device encryption and confirm where the key lives, then check aka.ms/myrecoverykey from a second device.⁴

99.89%

MICROSOFT DEFENDER'S REAL-WORLD PROTECTION RATE, AV-COMPARATIVES MARCH 2026 — AGAINST 99.97% FOR THE TOP-SCORING PAID SUITE²

The old advice was a second account. The 2026 answer is a temporary one — issued, used once, and thrown away.

ADMINISTRATOR PROTECTION — THE REAL STORY ON THIS PAGE

For twenty years the standard hardening advice was "run as a standard user, elevate only when needed" — advice most home users abandoned within weeks because too many installers assumed admin rights outright. Windows 11's **Administrator Protection**, first seen in Insider builds from October 2024 and rolling out broadly through 2025–26 via update KB5067036, replaces that model entirely: rather than a persistent admin token sitting on your logged-in account, every admin action spins up a temporary, Windows Hello-gated token for that one action and discards it immediately after.⁵ Microsoft's own framing is blunt — standing admin privilege is "a significant attack vector frequently abused by malicious actors." Enable it via Windows Security → Account protection, or the registry key on older builds, and your everyday account behaves like a standard one without the two-account friction that never stuck.⁶

SOURCES 1 AV-TEST, Microsoft Defender Antivirus (Consumer) 4.18 home-Windows results, Feb/Apr/Jun 2026 rounds, av-test.org. 2 AV-Comparatives, Malware Protection Test, March 2026; AV-Comparatives, "Is Microsoft Defender Enough? An Independent View." 3 Microsoft Support, Device Encryption vs. BitLocker guidance; itdef.net and thewindowsclub.com 2026 explainers. 4 Microsoft Support, "Back Up Your BitLocker Recovery Key" and "Find your BitLocker recovery key," aka.ms/myrecoverykey. 5 The Register, "Windows Insiders can now turn on Administrator Protection from settings," 18 Jan 2025. 6 Windows Forum, KB5067036 Administrator Protection rollout coverage, 2026.

Smart App Control — Windows 11's cloud-reputation app gatekeeper — got materially less punishing in 2026. Historically, switching it back on after disabling it required a clean Windows reinstall, a cost steep enough that most enthusiasts who wanted it simply never touched it. Windows 11 25H2 is reported to have removed that restriction, adding a direct toggle inside Windows Security.¹ Worth stating plainly for this exact reader, though: Smart App Control's cloud-reputation model is a poor fit for a machine that regularly runs self-compiled PyTorch wheels, unsigned community Python scripts, and freshly-cloned ComfyUI custom nodes — precisely the profile of a local-AI workstation. Treat it as the right default for the household's everyday-use machines, not a blanket recommendation for the GPU box.²

Two 2026 items belong specifically on this reader's radar. First, August's Patch Tuesday fixed **CVE-2026-68820**, a kernel-mode use-after-free in the Windows Sockets driver that Check Point attributed to active exploitation by North Korea's Lazarus Group, deploying an updated FudModule rootkit — a targeted, not mass-market, threat, but the kind of thing "install updates promptly" exists to catch.³

Second, and more mundane: the same update round fixed **CVE-2026-72971**, a tampering flaw in the Windows Container Isolation filter driver — directly relevant to anyone running Docker Desktop, which this workstation almost certainly does.⁴

Docker Desktop's own 2025 record supplies the strongest cautionary tale in this section. **CVE-2025-9074**, a critical (9.3/10) flaw fixed in v4.44.3, let any locally-running container reach Docker's internal management API — on the internal subnet, without the Docker socket even mounted — and spin up or control other containers, in some cases reaching toward the host filesystem. Researchers assessed the exposure as worse on Windows than macOS specifically because of how Docker's networking is wired there.⁵ The actionable habit this leaves behind: Docker Desktop updates on its own schedule, separate from Windows Update — it is easy to patch religiously and still be running a stale Docker Desktop for months. For anyone pulling community Docker images or Compose files (a routine act for ComfyUI and local-LLM serving stacks), Docker's own **Enhanced Container Isolation** feature is worth turning on.⁶

2027

THE STABLE CHANNEL YEAR MOST WINDOWS 11 22H2/23H2 MACHINES WILL HAVE RECEIVED SECURE BOOT CERTIFICATE ROLLOVER AUTOMATICALLY — CHECK MANUALLY IF A MACHINE HAS SAT UN-UPDATED FOR LONG STRETCHES³

THE SCEPTIC

None of this changes the honest bottom line: for a patched, Defender-protected, Administrator-Protection-enabled Windows 11 machine run by someone who doesn't click through ClickFix prompts, the marginal security gain from a paid antivirus suite in 2026 is small enough that the labs themselves now frame the comparison as a rounding error, not a verdict. Spend the subscription money on a hardware security key instead (p17) — it does more.⁷

QUICK HITS

Secure Boot certificates began expiring, June 2026. Most devices get the new certificate automatically; a machine left un-updated for long stretches risks a lapse.

Windows Hello Enhanced Sign-in Security now supports compatible external fingerprint readers — relevant for a desktop workstation with no built-in sensor.

RDP hardening. Remote Desktop now supports SHA-2 certificate thumbprints — worth checking if this workstation is ever accessed remotely rather than only at the desk.

WHAT THE LABS ACTUALLY MEASURE

AV-TEST and AV-Comparatives both publish their full methodology alongside every scored round — real-world protection tests run live malware samples against a fully-patched machine, not synthetic signatures — which is precisely why the Defender-versus-paid-suite gap this page opened with (p5) carries real weight rather than reading as a vendor's own claim. A reader who wants to verify the current numbers rather than trust this book's summary can check av-test.org and av-comparatives.org directly; both publish free, dated results.

SOURCES 1 Windows Forum, Smart App Control toggle coverage, Insider builds through 2026; Microsoft Learn, Smart App Control documentation (claim not independently primary-verified — flagged). 2 Editorial assessment, this edition. 3 The Hacker News and SecurityWeek, August 2026 Patch Tuesday coverage; Check Point Research, Lazarus/FudModule attribution. 4 Microsoft Security Response Center, August 2026 release notes, CVE-2026-72971. 5 TechRadar Pro, "A critical Docker Desktop security flaw puts Windows hosts at risk," Aug 2025; Docker Desktop 4.44.3 release notes. 6 Docker Docs, Enhanced Container Isolation. 7 Editorial synthesis of AV-TEST/AV-Comparatives 2026 rounds, this page.

THE SEAM NOBODY EXPLAINS WELL

The WSL2 Seam

A real Linux kernel, sharing a machine with Windows, invisible to most of the tools watching that machine — and, this year, a patch command that ran clean and left a known privilege-escalation bug fully intact.

this story  

WSL2 is not a compatibility shim. It is a real, purpose-built Linux kernel running inside a lightweight Hyper-V-backed virtual machine — a genuine VM boundary, stronger than a container, confirmed directly against Microsoft's own documentation.¹ That boundary has a shape most guides skip: every Linux distro installed on the machine — Ubuntu, Debian, whatever else — shares that ONE kernel instance and its network stack, differing only in their own process, mount and user namespaces. A kernel-level bug affects every distro on the box, not just the one where it was triggered.² And the boundary is a security-monitoring blind spot as much as a technical one: because WSL runs genuine Linux ELF binaries, Windows Defender does not scan them by default, Windows audit policies don't capture Linux process creation, and most consumer EDR tooling sees nothing but a quiet `wsl.exe` process while a full Linux toolchain runs underneath it. Researchers at Lumen's Black Lotus Labs documented the first confirmed malware campaign abusing exactly this gap to install payloads with no Windows-side footprint.³

The file-permission crossover this reader's brief specifically asked about has a precise, confirmed answer, not a folk one. Reaching Windows files from WSL2 (`/mnt/c/...`) does NOT use real Linux

permission bits by default — WSL calculates them live from your Windows account's actual NTFS access, so a file you can read-but-not-write on the Windows side shows as read-only to every user, group and other alike inside Linux. The optional `metadata` mount flag adds genuine Linux-style permission bits as NTFS extended attributes — but Microsoft's own documentation is explicit that even a file `chmod'd` to `777` under that flag cannot grant you more access than your Windows account actually has underneath it.⁴ The counterintuitive part, worth stating precisely: running `sudo` inside WSL2 gives you Linux root, not Windows privilege — `sudo rm` on a Windows-owned file you lack NTFS write access to still fails, because the filesystem checks the Windows security principal, and Linux "root" isn't one.

1

KERNEL — SHARED ACROSS EVERY WSL2 DISTRO ON A MACHINE, MEANING ONE KERNEL BUG REACHES ALL OF THEM²

Linux root is not Windows admin. The filesystem checks the Windows account underneath — "sudo" doesn't reach it.

"WSL --UPDATE" DIDN'T FIX IT — CONFIRMED FIRST-HAND

The strongest, most concrete finding in this section's research comes straight from GitHub, not a vendor summary. **CVE-2026-31431** ("Copy Fail") is a Linux kernel privilege-escalation bug, root-caused in code roughly nine years old, disclosed by researchers at Theori's Xint Code team. On 6 May 2026, a user on the public proof-of-concept repository directly confirmed exploiting it against WSL 2.6.3.0 running kernel 6.6.87.2-1 on Ubuntu 24.04 — and reported that running `wsl --update`, the standard advice, did not change the kernel version and did not patch the bug.⁵ The reason: WSL2's kernel ships on Microsoft's own build-and-update cadence via the Microsoft Store "Windows Subsystem for Linux" app, not through ordinary Windows Update and not through the Ubuntu/apt patching flow a Linux-native user would expect. The habit worth adopting: check `wsl --version` and compare against the current release directly, rather than assuming Patch Tuesday — or even a WSL update — covers it.

SOURCES 1 Microsoft Learn, WSL "Compare WSL versions" documentation, learn.microsoft.com/windows/wsl/compare-versions. 2 Same source; shared-kernel architecture across installed distros. 3 Truesec, "Microsoft Defender for Endpoint Plug-in for WSL"; TechRadar, "Hackers could turn Windows Subsystem for Linux into a secret weapon," citing Black Lotus Labs (Lumen) research. 4 Microsoft Learn, WSL file-permissions documentation, learn.microsoft.com/windows/wsl/file-permissions. 5 GitHub, [theori-io/copy-fail-CVE-2026-31431](https://github.com/theori-io/copy-fail-CVE-2026-31431), Issue #96, "Windows WSL2 (2.6.3.0, Kernel: 6.6.87.2-1) AFFECTED," 6 May 2026; corroborated by [microsoft/WSL Issue #40437](https://github.com/microsoft/WSL/issues/40437), opened same date.

"WSL2 ignores your firewall" is one of the most-repeated pieces of folk wisdom in home-networking forums, and it used to be true: a long-running Microsoft GitHub discussion documents a user in 2023 demonstrating that a Windows Firewall outbound block on port 22 did nothing to stop an SSH connection initiated from inside WSL2 — one commenter called it "a sick joke from Microsoft, bypassing its own security measures."¹ It is no longer accurate, and this book corrects it in print because the old advice is still circulating well past its expiry date: as of Windows 11 22H2 with WSL 2.0.9 and later, the Hyper-V firewall is enabled by default and Windows Defender Firewall's protections DO now apply to WSL traffic — confirmed directly against Microsoft's current networking documentation.² The remaining friction: this enforcement lives in Hyper-V VM-level firewall policy, configured via PowerShell cmdlets, not the familiar Windows Defender Firewall control panel — so a home user checking the normal GUI may not see where WSL's actual rules live, even though they are, in fact, being applied.

One further wrinkle for anyone who has enabled WSL's optional "mirrored" networking mode (useful for reaching a WSL-hosted dev server from another device on the LAN): a still-open Microsoft bug tracker issue documents the mode silently failing to select the right network adapter for some multi-adapter setups, falling back to a NAT address and

losing connectivity outright.³ If a local-LLM server or a ComfyUI instance needs to be reachable from a phone or another machine on the network, verify it actually is reachable from that second device — don't trust the setting alone.

2.0.9+

THE WSL VERSION, ON WINDOWS 11 22H2 AND LATER, AT WHICH THE HYPER-V FIREWALL BEGAN APPLYING BY DEFAULT — EARLIER FOLK WISDOM ABOUT WSL BYPASSING FIREWALLS IS NOW OUTDATED²

The compounding risk for THIS workstation specifically: a compromised `pip install` or `npm install` inside WSL2 doesn't stay contained to Linux. It has direct read access to anything the logged-in Windows user can read on `/mnt/c` by default — SSH keys, cloud CLI tokens, browser session data — the exact reverse of the isolation a Linux-native developer would assume. The practical countermeasures worth adopting, drawn straight from this year's incident record: keep credentials Linux-native inside the WSL filesystem rather than in a Windows-mounted folder; treat any fresh `pip/npm install` from an unfamiliar GitHub repo (routine for ComfyUI custom nodes) as worth reading before running, and consider a disposable WSL distro — cheap to spin up and tear down via `wsl --export/--import` — for anything untrusted rather than the primary dev environment holding real credentials.⁴

THE SCEPTIC

WSL2's blind spot is real, but proportion matters: the same 2025 research documenting cross-platform npm infostealers found them targeting Windows, macOS AND Linux simultaneously with equal success — meaning WSL2 offers zero protective benefit against a large share of the actual malware this reader is likely to encounter. The seam is a genuine, under-discussed risk; it is not a reason to trust the Linux side more than the Windows side.⁵

THE COMMUNITY'S OWN REACTION

The GitHub discussion that first documented WSL2's firewall bypass carried real, pointed frustration from IT practitioners at the time — one enterprise security commenter noted it affected "99 percent of enterprise Windows environments relying on centralised firewall controls," precisely because those teams assumed Windows Firewall covered everything running on the box.⁶ That the fix landed quietly, inside a routine WSL version bump, rather than as a headline security advisory, is itself a small lesson in how easily a real fix goes unnoticed while the original complaint keeps circulating online.

FOR THIS WORKSTATION SPECIFICALLY

Turn off VS Code auto-update for third-party extensions. Over 100 extensions leaked their own publisher tokens in 2025, letting a malicious update reach 125 million-plus installs with no user action (p24–25).

Check `wsl --version` directly rather than trusting `wsl --update` alone. At least one 2026 privilege-escalation bug survived the update command (p7).

SOURCES 1 GitHub, microsoft/WSL Discussion #10579, Oct 2023, directly cited. 2 Microsoft Learn, WSL networking documentation, learn.microsoft.com/windows/wsl/networking. 3 GitHub, microsoft/WSL Issue #12161, mirrored-networking adapter-selection bug, open as of this research. 4 Editorial synthesis from Unit 42 npm-supply-chain research and this page's WSL2 findings. 5 The Hacker News, "10 npm Packages Caught Stealing Developer Credentials on Windows, macOS, and Linux," Oct 2025. 6 GitHub, microsoft/WSL Discussion #10579, directly cited.

MACOS, 2026

The Other Half of the House

Gatekeeper checks provenance, not trustworthiness — and this summer's crop of Mac infostealers stopped trying to defeat it and started simply asking the user to let them in.

this story 

Gatekeeper's job is narrower than most Mac owners assume: it checks whether an app is signed by a known Apple Developer ID and has been notarised — scanned once by Apple, not tampered with since — not whether the app is actually trustworthy. XProtect, Apple's built-in signature scanner, runs alongside it, updated silently and frequently, with a periodic background sweep called XProtect Remediator that can auto-remove known malware.¹ None of it defends against a convinced user. The dominant Mac attack pattern this year is **ClickFix** (p3) landing on a fresh execution vector: a fake "your document failed to load" page tells the victim to open Script Editor, not Terminal, and paste a block of AppleScript — bypassing Gatekeeper entirely, because the user runs the payload themselves.²

A single family, Atomic Stealer (AMOS), has driven most of it. Microsoft's own security team named it in a February 2026 warning about macOS infostealers "actively exploited since late 2025," capable of lifting developer credentials — API keys, SSH keys — a detail

that matters directly to a household running local AI tooling.³ One documented distribution channel, "ClawHavoc," used a marketplace for AI-agent "skills" to push AMOS through 800-plus malicious listings impersonating crypto trackers and productivity integrations.⁴ A rebrand called MacSync went further in December 2025, shipping as a genuinely Apple-notarised app disguised as a messaging installer — abusing the notarisation process rather than breaking it, the clearest example in this book of the gap between "Apple approved it" and "it's safe."⁵

6

NAMED MACOS INFOTEALER FAMILIES OR CAMPAIGNS
DOCUMENTED SINCE LATE 2025 — AMOS, MACSYNC,
CRASHSTEALER, SHUB REAPER, INFINITI STEALER,
AMNESIASTEALER⁶

Apple approved it is not the same claim as it's safe — and this year's malware is built entirely around that gap.

THE FRESHEST ENTRY — LANDED THIS WEEK

As this book goes to print, Jamf Threat Labs is reporting **AmnesiaStealer**, discovered this month: a self-deleting, Rust-based stealer lured via a fake GitHub "Download for macOS" page, with OS-version-branched logic specifically written to route around already-patched bypasses, and a remote-control stage that steals cookies and patches browser fingerprinting APIs to dodge detection.⁷ It sits in a lineage that also includes July's **CrashStealer**, which disguised itself as Apple's own crash-reporting tool to lift passwords, Keychain data and crypto wallets — a name chosen specifically to look like part of the operating system.⁸

THE PATTERN ACROSS ALL SIX

Not one exploited a Gatekeeper code flaw. Every family on this page relies on either a convinced user (ClickFix) or an abused trust mechanism (notarisation, a spoofed system-tool name) — never a broken sandbox.

Developer credentials are the named prize. Microsoft's own February warning specifically flagged API keys and SSH keys as AMOS's target — directly relevant to any Mac used for development work alongside this household's Windows AI lab.

SOURCES 1 Macworld, "macOS Gatekeeper review"; Apple Support, "Protecting against malware in macOS"; Eclectic Light Co., XProtect Remediator explainer. 2 Infosecurity Magazine, "Atomic Stealer's ClickFix evolution"; Broadcom protection bulletin, AMOS ClickFix campaign. 3 Microsoft Security Blog, "Infostealers Without Borders: macOS, Python Stealers and Platform Abuse," 2 Feb 2026. 4 Trend Micro Research, "OpenClaw Skills Used to Distribute Atomic macOS Stealer," 2026. 5 The Hacker News, "New MacSync macOS Stealer Uses Signed...", Dec 2025; AppleInsider, 23 Dec 2025. 6 Synthesis of sources cited across this page and footnote 7–8. 7 Jamf Threat Labs via AppleWorld.Today and MacTech, 13 Aug 2026. 8 Help Net Security, "CrashStealer macOS infostealer," 14 Jul 2026; MacTrast, Jul 2026.

FileVault's recovery model changed under this year's release, macOS Tahoe 26, in a way worth a household actually checking rather than assuming. Previously, choosing iCloud-based recovery meant the key sat as retrievable escrow inside iCloud — meaning anyone with access to the account could pull it off a locked Mac. Tahoe reworks this to lean more heavily on trusted-device recovery (an iPhone, iPad or other Mac signed into the same Apple ID) rather than a simple escrow blob.¹ The practical consequence for a household with several Apple devices: generate a standalone recovery key and store it somewhere outside Apple's own ecosystem (a password manager entry, a safe), because Tahoe's model means losing every enrolled Apple device at once is now a real, if unlikely, lockout path.

TCC — the permission layer gating microphone, camera, screen recording and Full Disk Access — has a structural quirk worth knowing rather than a simple list of settings: SentinelLabs research found that Finder always holds Full Disk Access but is never listed in the Full Disk Access settings pane, so granting any app "Automation" control over Finder silently inherits that access — and, unlike granting FDA directly, doing so requires no admin password.² A separate flaw, CVE-2025-43530, let an attacker manipulate a VoiceOver-accessibility service to send AppleEvents to any process — including Finder —

without triggering any TCC prompt at all; Apple's own fix in macOS 26.4 specifically targets the ClickFix paste pattern (p3), warning users before they paste content that could be dangerous into Terminal or Script Editor.³

26.3

THE MACOS TAHOE POINT RELEASE, FEB 2026, CONFIRMED VIA APPLE'S OWN ADVISORY TO FIX A GATEKEEPER BYPASS REACHED BY A MALICIOUSLY CRAFTED ZIP ARCHIVE⁴

One genuine zero-day earned the year's alarm: **CVE-2026-20700**, a dyld memory-corruption flaw found by Google's Threat Analysis Group and confirmed by Apple to have been used in highly targeted attacks against specific individuals, patched across iOS, iPadOS and macOS 26.3 in an exploit chain with two earlier WebKit zero-days.⁵ This is mercenary-spyware-class targeting, not something the median household is likely to face directly — but it is the honest reason "install updates promptly" earns its place in this book rather than being boilerplate. For anyone genuinely worried about being an individually targeted person, Apple's Lockdown Mode remains the tool; Apple states plainly it is aware of no successful mercenary-spyware attack against a Lockdown-enabled device — a strong claim, and one this book flags rather than recommends broadly, given the real functionality it strips away.⁶

STILL ON THE SHELF

CVE-2026-28914 (Gatekeeper ZIP bypass). Fixed in macOS Tahoe 26.5 — a reminder that a fully patched Mac in 2026 has already absorbed at least one real Gatekeeper-bypass fix this year.

Three OS generations under active support. Tahoe 26 (current), Sequoia 15 (security-only through Jan 2028), Sonoma 14 (security-only, ends 26 Sep 2026) — a Sonoma household has roughly six weeks of patches left as this book goes to print.

THE HOUSEHOLD'S PRACTICAL CHECKLIST

For this exact mixed household, the actionable list from this section runs short and specific: confirm FileVault has a standalone recovery key stored outside the Apple ecosystem, not just iCloud escrow; audit Full Disk Access and Automation grants periodically, since the Finder-inheritance quirk means a seemingly minor "control Finder" prompt is really a Full Disk Access grant in disguise; and extend the household's ClickFix training (p3) explicitly to Script Editor, not just Terminal — the vector this year's Mac malware actually used.

THE SCEPTIC

Objective-See founder Patrick Wardle's own running assessment of the Mac malware landscape converges on the same point this whole section makes in different words: the operating system's defences are not the weak point. ClickFix works on Windows and Mac alike, at similar rates, using the same trick — a convinced user, not a broken sandbox. A household that trains itself to distrust copy-pasted terminal commands closes more of this year's actual attack surface than any single macOS setting does.⁷

SOURCES 1 Six Colors, FileVault/Tahoe recovery-model reporting, Sept 2025 (secondary-summarized; recommend direct verification against Apple's own FileVault documentation). 2 SentinelLabs, "Bypassing macOS TCC User Privacy Protections By Accident and Design." 3 Mickey Jin, CVE-2025-43530 technical writeup; SecurityOnline summary; Objective-See blog, "No Paste for You!," Mar 2026 (title/date via secondary summary). 4 SentinelOne CVE database, CVE-2026-28914; Apple security advisory, macOS Tahoe 26.5. 5 The Hacker News and Security Affairs, Feb 2026, CVE-2026-20700 reporting. 6 Apple Support, "About Lockdown Mode"; MacTech, 27 Mar 2026. 7 Objective-See Foundation blog index, 2026 annual Mac malware report (secondary-summarized).

THE NEW FRONT DOOR

Identity as the Perimeter

Five billion passkeys now exist worldwide, and a six-digit code can still be phished in real time by a proxy site that looks perfect — the honest 2026 gap between what's cryptographically solved and what still isn't.

this story  

Passkey adoption crossed a real threshold this year. The FIDO Alliance's May 2026 State of Passkeys survey — 11,000 consumers across ten countries — found 90 percent awareness, 75 percent of respondents with a passkey enabled on at least one account, and an estimated five billion passkeys in active use worldwide.¹ The mechanism explains why security teams keep pushing it: a passkey performs origin-bound cryptographic verification, meaning the credential is tied to the real site's actual domain. A phishing proxy — even one that mirrors the real login page pixel-for-pixel — cannot complete the handshake, because the browser checks the origin before the private key ever signs anything. This is the precise, technical reason "phishing-resistant" is an accurate term rather than marketing.²

TOTP codes offer no such protection, and 2025–26 supplied the proof at scale. **Evilginx**-based adversary-in-the-middle kits sit between a victim and the genuine login page, relaying the real flow both directions — forwarding username, password AND whatever six-digit code the victim types — then

capturing the session cookie issued after MFA succeeds. That cookie is the actual prize: with it, an attacker is logged in without ever needing MFA again. One campaign hit at least eighteen US universities between April and November 2025 via roughly seventy proxy domains mirroring institutions' own single sign-on pages; a second wave targeted Microsoft 365 users through 2026, exposed by a misconfigured operator server in July.³ NIST's own 2025 guidance (SP 800-63B) now codifies the hierarchy this implies: at its top assurance tier, authentication **REQUIRES** a phishing-resistant authenticator with a non-exportable private key — not merely offers one as an option.⁴

5B

ESTIMATED PASSKEYS IN ACTIVE USE WORLDWIDE, FIDO ALLIANCE, MAY 2026¹

A perfect copy of a login page still can't complete a handshake the browser itself refuses to authorise.

EVEN PASSKEYS HAVE A SUPPLY CHAIN

Passkeys are not a solved problem, and this book prints the honest caveat rather than pure boosterism. Palo Alto Networks' Unit 42 published research in early August 2026 — "Pass-ta-key" — describing three attack paths against Chrome's Google Password Manager cloud sync, the most severe of which extracts the master Security Domain Secret from Chrome's process memory, decrypting every synced passkey past and future. All three require malware already running on the endpoint first; none breaks the underlying WebAuthn cryptography. No equivalent published research exists yet against Apple's iCloud Keychain sync specifically.⁵ Hacker News' own community response to the coverage was notably unimpressed rather than alarmed — commenters pointed out the described behaviour "is not novel" and criticised the reporting for glossing over backup-eligibility nuances that actually determine the real risk.⁶

SOURCES 1 FIDO Alliance, "State of Passkeys 2026," released World Passkey Day, 6 May 2026. 2 GoTrustID and TerraZone, phishing-resistant MFA / FIDO2 origin-binding explainers, 2026. 3 Malwarebytes, "Attackers have a new way to slip past your MFA," 3 Dec 2025; Rescana, Microsoft 365 Evilginx campaign exposure, 13 Jul 2026. 4 NIST SP 800-63B (2025 revision); IDManagement.gov Phishing-Resistant Authenticator Playbook. 5 BleepingComputer, TechRadar Pro, 9to5Google, The Hacker News — Unit 42 "Pass-ta-key" coverage, ~4 Aug 2026. 6 Hacker News discussion thread, item 49176644, paraphrased community reaction.

LastPass's 2022 breach is still generating harm four years on, and the running tally is the clearest cautionary tale in this book about what a single vault compromise actually costs downstream: over \$35 million in traced crypto theft by 2023, a further \$150 million attributed to the same stolen vault data by 2025, a UK ICO fine of roughly £1.2 million, a \$24.5 million US class-action settlement, and — as recently as January 2026 — a fresh, unrelated phishing campaign using fake "maintenance notification" emails to harvest master passwords from the same user base.¹ The company says it has rebuilt its infrastructure and controls since 2022; the honest framing is that the question stays open rather than resolved.

Its two leading rivals had their own 2026 moments. Bitwarden confirmed a brief supply-chain incident in April 2026: a malicious package was live in the npm distribution path for its CLI tool for roughly ninety minutes, containing a credential-stealing payload — Bitwarden's own statement is explicit that this affected only the CLI distribution channel, not vault encryption or synced passwords, a distinction some headline coverage blurred by citing the full ten-million-user base rather than the actual, much narrower exposure window.² Both 1Password and

Bitwarden also raised prices in the first quarter of 2026 — Bitwarden's Premium tier nearly doubling, described in coverage as its first major increase in roughly a decade — a trend that makes the free, self-hosted tier (Vaultwarden, a Rust reimplementation of Bitwarden's server API, or fully offline KeePassXC) a genuinely more attractive "custom" option for a household already running its own home-lab infrastructure, not just a budget one.³

\$24.5M

LASTPASS'S 2025 US CLASS-ACTION SETTLEMENT OVER ITS 2022 BREACH — FOUR YEARS AND COUNTING OF MEASURABLE, ONGOING HARM¹

SIM-swapping and credential stuffing round out why this desk sits ahead of the network chapter, not behind it: FBI figures put US SIM-swap losses near \$26 million a year, and industry threat-intel teams (Verizon, IBM X-Force, CrowdStrike) converged independently on the same 2025–26 conclusion — stolen or reused credentials remain the dominant initial-access vector for real intrusions even as vulnerability exploitation edges ahead in the aggregate breach count (p3). A hardware security key or a passkey defeats both attack classes at once; a strong-but-typed password defeats neither reliably.⁴

STILL ON THE SHELF

The "16 billion password leak," June 2025. Circulated widely as a fresh breach; researchers characterised it as a compilation of roughly thirty older breach datasets, not one new incident. Worth knowing before repeating the headline.

UK NCSC now recommends passkeys as the default login method over traditional passwords where available — a genuine shift from decades of complexity-focused password guidance.

THE SCEPTIC

Passkeys reduce the value of a stolen password, and attackers have already adapted rather than given up — Microsoft's own July 2026 threat reporting describes the fight moving toward account-RECOVERY flows, "verify your identity" re-authentication prompts and AI-generated impersonation instead of the login form itself.⁵ A household that adopts passkeys everywhere but leaves its account-recovery email protected only by a reused password has moved the weak point, not closed it.

THE MIGRATION PATH, STATED PLAINLY

For a household weighing whether to actually move off LastPass or a legacy manager: every major alternative (1Password, Bitwarden, Proton Pass) offers a direct import tool for LastPass's own export format, and the migration itself takes under an hour for a typical vault. The harder part is habit, not technology — rotating the passwords LastPass actually knew about, not just moving the vault file. This book's own recommendation, weighing price against the self-hosted option this exact reader is equipped to run: Bitwarden Families for the household members who won't manage their own server, Vaultwarden for the reader who will.

SOURCES 1 Cyber Unit, "LastPass Issues Critical Warning," Jan 2026; SecurityScorecard, LastPass breach retrospective. 2 Forbes, 24 Apr 2026 (headline framing flagged); Next Century, Bitwarden CLI incident coverage. 3 itechguides and guptadeepak 2026 password-manager pricing roundups; Bitwarden Premium pricing change, Jan 2026. 4 Efani, SIM-swap statistics 2026 (FBI IC3 data); SecureW2 synthesis of Verizon/IBM X-Force/CrowdStrike 2026 threat reporting. 5 The Hacker News, "The Verification Step Is the New ATO Battleground in 2026," Jul 2026.

WHAT CARRIES ALL OF IT

The Network Layer

Fifty thousand ASUS routers, hijacked through vulnerabilities Asus had already patched, spent 2025 doing nothing but sit there quietly — because nobody rebooted, let alone updated, the box in the closet.

this story 

Stock router firmware is the weakest link in most home networks, and 2025–26 supplied the receipts by brand. TP-Link shipped fixes for hardcoded credentials embedded in a firmware password file (CVE-2026-12001) and an unauthenticated command-execution flaw in several Archer and DSL router lines, prompting Singapore's own Cyber Security Agency to flag the Archer line as critical.¹ Netgear patched an unauthenticated remote-code-execution bug in its XR1000-series gaming routers (CVE-2025-25246) requiring no credentials or user interaction at all. ASUS patched a critical AiCloud flaw chaining path traversal and command injection (CVE-2025-59366, CVSS 9.8) — and separately, six mostly-legacy AiCloud vulnerabilities in end-of-life ASUS models were chained by a campaign researchers dubbed **Operation WrtHug** to build a botnet of more than fifty thousand hijacked routers, concentrated in Taiwan, the US and Russia.²

The pattern underneath all of it, confirmed by vulnerability-intelligence firm VulnCheck's 2026 State of Exploitation report: consumer routers and

networking gear account for 56 percent of exploited edge-device vulnerabilities, and 65 percent of those affect end-of-life or near-end-of-life products.³ The old router still plugged in behind the TV, three models past its last update, is the actual risk — not this year's flagship. A second botnet, KadNap, discovered infecting 14,000-plus edge devices (mostly ASUS routers) exploited already-patched flaws, not novel ones, and — worth the reminder — a simple reboot doesn't clear it; a full factory reset, firmware update and credential rotation are required.⁴

65%

SHARE OF BOTNET-EXPLOITED EDGE-DEVICE
VULNERABILITIES IN 2026 AFFECTING END-OF-LIFE OR
NEAR-EOL PRODUCTS, VULNCHECK³

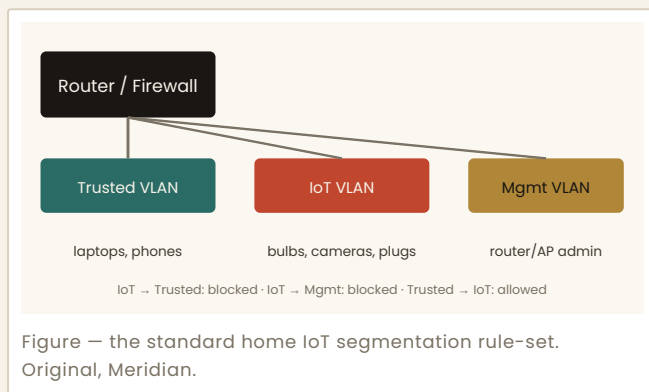
The router three firmware versions behind, quietly working in the closet, is the actual risk — not this year's flagship.

THE DNS-FILTERING HONESTY CHECK

Pi-hole, NextDNS, Control D and Quad9 all genuinely block known malware and phishing domains before a connection completes — Quad9 alone is measured at roughly 97 percent effectiveness against malware/phishing domains in independent evaluation.⁵ The limitation worth printing plainly: modern operating systems and apps increasingly hardcode their own encrypted-DNS endpoints (DoH/DoT/DoQ over port 443/853), which quietly bypasses router-level DNS redirection entirely — CISA has published guidance on exactly this gap for enterprise networks, and the same physics applies at home. DNS filtering is one layer, not a wall; pair it with the network segmentation below rather than treating it as sufficient alone.⁶

SOURCES 1 TP-Link security advisory FAQ 5210/5027, tp-link.com; CSA Singapore Alert AL-2026-028. 2 SentinelOne CVE database, CVE-2025-25246; SecurityAffairs, ASUS AiCloud advisory; SecurityWeek and The Hacker News, "Operation WrtHug," Nov 2025. 3 VulnCheck, "2026 State of Exploitation" report, State of the Network Edge. 4 BleepingComputer, TheHackerNews, SecurityAffairs — KadNap botnet reporting, Mar 2026. 5 factually.co and shieldcue.com, Quad9 effectiveness evaluation, 2026. 6 CISA, "Encrypted DNS Implementation Guidance"; XDA-Developers, "Your DNS filters are probably being bypassed."

The threat model behind IoT segmentation is specific, not superstition: a compromised smart bulb or camera should be able to phone its own cloud service and nothing else — never reach a NAS, a laptop, or intercept LAN traffic. The standard rule-set — IoT VLAN blocked from the trusted VLAN and the management VLAN, allowed only outbound to the internet, with the trusted VLAN allowed inbound to IoT for administration — is achievable on consumer-grade managed switches paired with UniFi, Firewalla or an OPNsense box, in roughly an hour of configuration.¹



Matter and Thread actively fight this design, and the household's own Lutron-to-Home-Assistant migration runs directly into it. Matter-over-Thread commissioning depends on mDNS, a link-local multicast protocol that does not cross VLAN boundaries by default — practitioner write-ups converge on pairing a phone, the Home Assistant instance and the Thread border router on the SAME VLAN just long enough to commission, then re-segmenting afterward, or configuring an mDNS reflector (Avahi, UniFi's built-in relay, or OPNsense's mDNS repeater package) to bridge it properly.² Even with a reflector in place, some users report ongoing flakiness — devices intermittently vanishing from Home Assistant. This is the honest caveat: segmenting a Matter/Thread household is not "set and forget" the way isolating a security camera is.

Lutron's own Caseta bridge (both the standard and Pro models) is explicitly recommended by community integration guides for isolation on its own IoT VLAN as best practice — worth noting that the Pro bridge requires Telnet enabled for the Home Assistant integration to work, an extra exposed service worth firewalling off from anything but the Home Assistant host specifically.³

THE SEGMENTER

COMMUNITY CONSENSUS

"IoT VLAN isolation is the single highest-leverage change most smart-home households haven't made — a compromised bulb should never be able to reach a NAS."

THE SCEPTIC

ANANDTECH / CISCO FORUMS

"A single, well-configured router with NAT is adequate for most homes that don't run public-facing servers; stacking firewall layers mostly adds complexity, not measurable security."⁴

THE SCEPTIC, ON REMOTE ACCESS

Port-forwarding a NAS or Home Assistant to the internet keeps a permanently scanned, permanently exploitable surface open — the standard case for Tailscale-style overlay meshes instead, which use NAT traversal and a coordination server for key exchange only, with actual traffic routed peer-to-peer.⁵ The dissent worth printing: this trades one risk for a dependency on a third-party coordination service staying available and honest. Headscale, an open-source reimplementation of Tailscale's control plane, exists for households that want the same client experience while owning that piece themselves.

SOURCES 1 Botmonster and XDA-Developers, smart-home VLAN segmentation guides, 2026. 2 ndo.dev, hierl.dev, travishale.com — Matter-over-Thread-and-VLANs practitioner write-ups (secondary-summarized); Home Assistant official Matter integration docs. 3 Home Assistant, official Lutron Caseta integration documentation. 4 Anandtech Forums, home-firewall-device discussion thread, aggregated community sentiment. 5 XDA-Developers, "Stop port forwarding your self-hosted services"; Tailscale homelab use-case documentation.

THE FAILURE MODE THAT ACTUALLY MATTERS

The Last Line

A Romanian gang ran a NAS-targeting ransomware operation for four years before Europol finally shut it down — long enough that "I'll set up backups eventually" stopped being a plan and became the actual exposure.

this story  

The old 3-2-1 rule — three copies, two media types, one offsite — has a working 2026 successor: **3-2-1-1-0**, adding one immutable or air-gapped copy and zero tolerated restore errors, meaning restores are actually tested, not assumed.¹ The "1" for immutability is no longer exotic on consumer hardware. Synology's DSM 7.2 standardised immutable snapshots on Btrfs volumes — once a retention window is set, a snapshot cannot be deleted even by a compromised administrator account — and QNAP's QuTS hero platform offers an equivalent through its Ransomware Guard feature and KMIP key management.² Pair one immutable target with one genuinely offline copy — an external drive, disconnected after each backup, rotated between two drives if the household can manage it — and a ransomware payload has nothing left to encrypt that matters.

Consumer and prosumer NAS devices are a proven, not theoretical, ransomware target. Europol's July 2025 "Operation Elicius," with Italian, French and Romanian police, dismantled a gang — operating as DiskStation Security, Quick Security and Umbrella

Security — that had targeted Synology NAS devices specifically since 2021, demanding ransoms from \$10,000 to several hundred thousand dollars from victims across Italy's Lombardy region.³ A newer, more targeted variant of the older eCh0raix ransomware family, documented by Unit 42, is the first to combine QNAP-targeting and Synology-targeting code in a single payload — evidence that ransomware developers keep investing specifically in home and small-business NAS as a target class, not treating it as an afterthought.⁴

4 yrs

HOW LONG THE "DISKSTATION" RANSOMWARE GANG OPERATED AGAINST SYNOLOGY NAS DEVICES BEFORE A 2025 EUROPOL TAKEDOWN³

Every source in this section converges on the same mitigation: never expose the NAS admin panel directly to the public internet. It is the entry point for nearly all of it.

"I WAS TOLD TO MAKE BACKUPS, NOT TEST THEM"

The Register's own reader-submitted disaster-recovery stories supply the cautionary texture this section needs: one organisation's backup software reported a tape as "verified" for a full year while writing nothing to it, discovered only when the tape was pulled for rotation and found blank. In a sharper irony, backup vendor Veeam itself restored a one-day-old backup over its own live forum database during routine maintenance in February 2025, permanently losing everything written in between.⁵ The practical rule this leaves behind: a restore that has never actually been run, end to end, onto a spare drive, is not a backup — it's an assumption wearing a backup's clothes.

SOURCES 1 AvePoint, "What Is the 3-2-1 Backup Rule and Why It's Evolved to 3-2-1-1-0?," 2026; TechTarget, 3-2-1-1-0 explainer. 2 Synology official, "Immutable Backup: The Only Thing Ransomware Can't Touch"; QNAP, ransomware-solution product page. 3 BleepingComputer, "Police disrupt 'Diskstation' ransomware gang attacking NAS devices," Jul 2025; GBHackers, SC Media, Fortra corroborating coverage. 4 Unit 42 (Palo Alto Networks), eCh0raix SOHO-targeting ransomware research. 5 The Register, "To avoid disaster-recovery disasters, learn from Reg readers' experiences," 1 Apr 2025; "Backup software vendor Veeam deleted forum data after restoration SNAFU," 17 Feb 2025.

Priced honestly, a real 3-2-1-1-0 setup for this household doesn't require enterprise spend. A prosumer NAS with immutable-snapshot support anchors it: Synology's DS925+ (4-bay, AMD Ryzen V1500B, ECC RAM, dual 2.5GbE) runs roughly US\$600–680 diskless, and the 5-bay DS1525+ around US\$800; QNAP's TS-464 (4-bay, dual 2.5GbE) sits near US\$470–730 depending on RAM configuration.¹ A cloud layer completes the offsite copy: Backblaze Personal Backup runs roughly US\$9/month or about US\$70/year for unlimited storage per computer, with 30-day version history extendable to a full year for a small add-on fee; iDrive Personal's promotional first-year pricing runs US\$79.50–99.50 for 5–10TB, though renewal pricing after year one is materially higher and worth checking before committing.²

For a household already running self-hosted infrastructure, Backblaze's B2 object storage (roughly US\$6–7 per terabyte per month, with generous free egress via CDN partners) is the natural target for a NAS's own automated offsite job, rather than a second consumer subscription.³ Arq Backup — software that points at your own choice of cloud storage — is a genuinely relevant "custom" option for

this exact reader, priced at US\$49.99 per computer today, rising to US\$59.99 from 1 September 2026, its first increase in over a decade.⁴

3-2-1-1-0

3 COPIES · 2 MEDIA TYPES · 1 OFFSITE · 1 IMMUTABLE/AIR-GAPPED · 0 UNTESTED RESTORES¹

The realistic monthly cost for this household's full backup ladder, priced from the figures above: roughly US\$9–15 a month in cloud subscription, against a one-time US\$600–800 NAS purchase amortised over its working life — genuinely modest set against the buy-once-cry-once gear a few pages ahead (p17), and cheaper than a single paid antivirus subscription this book's own Desktop Perimeter chapter (p5) argues is often unnecessary.

3-2-1-1-0, mapped to real hardware

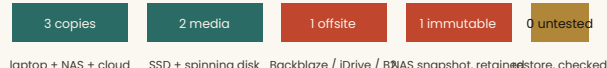


Figure — the 3-2-1-1-0 rule mapped to a real household's hardware. Original, Meridian.

A RESTORE-TESTING SCHEDULE THAT ACTUALLY STICKS

The practitioners cited across this desk converge on the same fix for the "verified for a year, wrote nothing" failure mode (p15): put a restore test on the same calendar as a birthday, not a to-do list. Once a quarter, pick one file from the immutable snapshot and one from the offsite cloud copy, restore each to a throwaway folder, and confirm it opens. It takes minutes and it is the only step in this whole ladder that actually proves the other four are working.

1x/qtr

THE RESTORE-TEST CADENCE THIS BOOK RECOMMENDS — THE CHEAPEST, MOST-SKIPPED STEP IN THE ENTIRE BACKUP LADDER

HELD FOR VERIFICATION

Synology's drive-lock policy. A well-documented 2025 controversy saw Synology move toward requiring Synology-validated drives to unlock full features on certain newer Plus-series units — this book flags it rather than asserting the current 2026 policy status, since coverage of any walk-back could not be confirmed this session.

QNAP's December 2025 incident. A threat actor claimed unauthorised access to a single QNAP device (a TS-228 running outdated firmware) and 1.7TB of data for resale; QNAP's own statement disputes this as a broader breach. Treat as a single-device claim, not a confirmed wave.

THE SCEPTIC

A 3-2-1-1-0 setup is aspirational for most households, not descriptive — this book prints the ladder honestly rather than pretending it's already common practice. The Register's own reader-submitted "verified" backup that wrote nothing for a year (p15) happened at an organisation with a dedicated IT function; a home user with no restore-testing discipline at all is not a worse case, just an untested one. The single highest-leverage fix on this page is the cheapest: actually restore one file from the backup, once, on a schedule — not buy a second NAS.

SOURCES 1 Marius Hosting, iFeeltech and Dong Knows Tech, Synology DS925+/DS1525+ reviews and specs, 2026; StorageReview and QNAP official specs, TS-464. 2 StackScored, costbench, Cloudwards — Backblaze Personal and iDrive Personal 2026 pricing (secondary-aggregated; verify at point of purchase). 3 comparebestai.com, Backblaze B2 pricing summary. 4 Arq Backup official pricing page; BestBackupReviews, price-increase notice.

THE BOOK'S DEEPEST DESK

The Gear

In April, hardware security keys were the enthusiast's extra step. By June, OpenAI made them mandatory for its highest-privilege AI accounts — the clearest "this actually changed something" signal anywhere in this book.

this story 

Hardware security keys are the one purchase every desk in this book agrees on, and the entry point is genuinely a real entry point now, not a compromise. Google's Titan Security Key runs US\$30 (USB-A/NFC) or US\$35 (USB-C/NFC), FIDO2/U2F only. The community's default "buy this one" recommendation, repeated across 2026 buyer's guides, is the **YubiKey 5C NFC at US\$58** — broadest protocol support (FIDO2/WebAuthn, U2F, OTP, PIV, OpenPGP) plus NFC for phone use. The standing practitioner advice: buy at least two, register both to every account, and keep one physically separated — a safe-deposit box, a different building — so a house fire or a lost bag doesn't lock you out of your own accounts.¹ A budget alternative, Token2's T2F2 FIDO2/U2F key, runs about US\$22. One open-hardware cautionary tale belongs on this page too: SoloKeys' Solo 2 is still sold, but its GitHub repository has sat essentially untouched for roughly two years — a real risk for a buy-once-cry-once reader who wants long-term firmware support behind a purchase.²

US\$58

YUBIKEY 5C NFC — THE COMMUNITY'S DEFAULT
RECOMMENDATION FOR A HOME POWER-USER'S FIRST
HARDWARE KEY¹

The cutting-edge story this year didn't come from a new key model — it came from a policy change. On 30 April 2026, Yubico and OpenAI announced a custom two-key bundle (a YubiKey C NFC plus a YubiKey C Nano) sold specifically to secure ChatGPT accounts; by 1 June 2026, hardware-backed passkeys became MANDATORY, not optional, for OpenAI's highest-privilege "Trusted Access for Cyber" tier working with its most capable, agentic models.³ Security professionals are already citing this as the leading edge of "AI-agent identity" security — the first mainstream case of an AI vendor requiring physical key possession rather than merely recommending it. A firmware update in July (YubiKey 5.8) separately cut down on repeated PIN prompts during passkey selection — a small but real fix aimed at the exact friction that makes a hardware key hard to hand to a less technical household member.⁴

The first mainstream AI vendor to require a physical key, not just recommend one, did it in five weeks flat.

PASSWORD MANAGERS AS A PURCHASE

1Password Families runs US\$6.99/month for up to five people (a March 2026 price rise from US\$5.99); Bitwarden Families runs US\$3.99/month, or US\$47.88/year, for up to six — cheaper, open-source, and the pick most switchers from 1Password report satisfaction with despite a less polished interface, citing the ability to actually inspect the code as the deciding factor.⁵ Proton Family bundles a full Proton Unlimited subscription (Mail, Drive, Calendar, 500GB, plus Pass) for US\$19.99/month — a genuinely different value proposition, not a pure password-manager comparison. The real "custom/pro" tier for a home-lab-capable household: **Vaultwarden**, a Rust reimplement of Bitwarden's server API running on a spare Raspberry Pi or a US\$5/month VPS, unlocking Bitwarden's premium features for free, indefinitely — or fully offline **KeePassXC**, which now holds ANSSI (the French national cyber agency's) Security Visa certification and added real passkey support in 2026, with the caveat that it still lacks passwordless/usernameless login and needs manual cloud-sync configuration.⁶

SOURCES 1 Yubico official store and product pages; criticnest.com and allthingssecured.com 2026 hardware-key buyer's guides. 2 Token2 store; GitHub, solokeys/solo2 discussions #174; b.j4.lc retrospective, "SoloKeys three years after," Feb 2026. 3 Yubico press release, "OpenAI and Yubico Partner to Bring Custom Phishing-Resistant YubiKeys," 30 Apr 2026; Help Net Security and BiometricUpdate, 1 Jun 2026. 4 cybersecuritynews.com, "YubiKey 5.8 Released," 21 Jul 2026. 5 subkept.com and buyersprint.com, 1Password 2026 pricing; costbench.com and Bitwarden's own blog, Bitwarden Families pricing. 6 Vaultwarden project documentation (GitHub); keepassxc.org; Corbado, KeePassXC passkey-support analysis.

For the network layer's hardware (p13), the buy-once-cry-once ladder runs cleanly across four tiers. **Firewalla:** Purple SE at US\$249 (entry), Gold SE at US\$479 (the sweet-spot pick most 2026 buyer's guides converge on), Gold Plus at US\$599, Gold Pro at US\$899 for households wanting multi-gig throughput with deep packet inspection.¹ **UniFi:** Cloud Gateway Max around US\$244, the new Wi-Fi 7 Dream Router 7 at US\$279, the mid-tier UDM-Pro-Max at roughly US\$500, and the Dream Machine Beast at US\$1,499 for the household that wants the top of the consumer line. **TP-Link Omada's** new Fusion Gateway, launched July 2026 at US\$169.99, undercuts both — a genuine controller-plus-gateway-in-one at a lower price point, TP-Link's direct answer to UniFi's format.²

The true custom/pro tier is a Protectli Vault running self-configured OPNsense or pfSense — a four-port box runs roughly US\$420–480, smaller two-port configurations closer to US\$200–330. Community sentiment has genuinely shifted here: Netgate's push

toward a closed-source, subscription-priced "pfSense Plus" (roughly US\$129/year if not run on Netgate's own hardware) has moved enthusiast consensus toward **OPNsense** as the default — fully open source, weekly security releases, native WireGuard support.³ Worth the honest caveat: OPNsense isn't immune either — a documented seven-day stretch in 2026 patched two critical remote-code-execution bugs in a single point release, a real reminder that self-hosting a firewall trades vendor negligence risk for your own patch discipline.⁴

US\$479

FIREWALLA GOLD SE — THE PRICE POINT MOST 2026 BUYER'S GUIDES CONVERGE ON AS THE SWEET SPOT, NOT THE ENTRY TIER OR THE FLAGSHIP¹

For the backup layer's hardware, see p16 in full — the Synology DS925+/DS1525+ and QNAP TS-464 pricing sits there rather than repeating it here, since it belongs to the immutable-snapshot discussion specifically.

THE FOUR APPLIANCE LADDERS, SIDE BY SIDE

BRAND	ENTRY	SWEET SPOT	TOP OF LINE
Firewalla	Purple SE \$249	Gold SE \$479	Gold Pro \$899
UniFi	Cloud Gateway Max \$244	UDM-Pro-Max ~\$500	Dream Machine Beast \$1,499
TP-Link Omada	Fusion Gateway \$170	—	ER8411 \$399
Protectli + OPNsense	2-port ~\$200–330	4-port ~\$420–480	bring your own scale

All prices as researched Aug 2026 from official vendor pages and reviews; verify before purchase.

ENDGAME VS. REGRET, BY BRAND

Enthusiast guides converge on a similar shape across all four ladders: the entry tier gets outgrown within a year by anyone reading this section closely enough to be here; the sweet spot is where most households actually land and stay; and the top tier is bought more often for the throughput number than for a capability the household ends up using. Firewalla is specifically praised for making segmentation approachable to a non-network-engineer; UniFi for its polished all-in-one controller UI; the self-built Protectli route for owning the stack outright, at the cost of real setup time.

THE SCEPTIC, ON THIS WHOLE PAGE

Reviewers covering Firewalla's own top-tier Gold Plus and Gold Pro models routinely note they are "likely overkill for home users," with the Purple and Blue Plus tiers judged more than capable for most households — and community sentiment on UniFi's Dream Machine line runs the same way: VLANs and advanced firewall rules are available, genuinely useful for some households, and overkill for most of the people buying the hardware to get them.⁵ Buy for the segmentation and the DNS-filtering control this book actually recommends (p13–14) — not for the throughput number on the box.

SOURCES 1 help.firewalla.com buyer's guide; MightyGadget Gold Plus review, 8 Apr 2026; firewalla.com official product pages. 2 iFeeltech UniFi Gateway Comparison 2026; Dong Knows Tech, TP-Link Fusion Gateway launch coverage, Jul 2026. 3 DIYMediaServer, HomelabAddiction, WiredHaus, TechFuelHQ — OPNsense-vs-pfSense 2026 homelab comparisons. 4 wz-it.com, OPNsense 26.1.8 CVE patch-week coverage (secondary-summarized; CVE numbers flagged for verification). 5 TechRadar, Firewalla Gold review; SmartWired and technodabbler.com, UniFi Dream Machine "overkill for home" commentary.

Tailscale is the network layer's own gear pick, not a separate VPN-for-privacy purchase — its free personal tier covers up to 100 devices, comfortably enough for a household's laptops, phones, the NAS and a Home Assistant box, and it directly solves the CGNAT problem that many Singapore ISP and mobile connections otherwise make port-forwarding impossible for anyway.¹ This book deliberately does not recommend a commercial "VPN for security" subscription as home-security gear — the honest reasons why are the Sceptic desk's opening argument (p23), not a gap here.

The custom tier, gathered in one place: **Vaultwarden** and **KeePassXC** for identity (p17); a self-built **Protectli** + **OPNsense** box for the network (this page); **Headscale**, an open-source reimplementation of Tailscale's coordination server, for a household that wants the same client experience while owning the control plane itself rather than trusting a third party's coordination service to stay available; and **Arq**

Backup pointed at Backblaze B2 for a fully self-directed backup pipeline (p16). None of it requires spending more than the appliance tier above — the "custom" premium here is time and comfort with a config file, not dollars.

100

DEVICES COVERED ON TAILSCALE'S FREE PERSONAL TIER — ENOUGH FOR A WHOLE HOUSEHOLD'S LAPTOPS, PHONES, NAS AND HOME ASSISTANT BOX¹

Community sentiment on the custom tier, gathered across this book's research, converges on a single honest tradeoff: Vaultwarden and Headscale both ask a household to become, in effect, its own tiny hosting provider — uptime, updates and backups of the vault-of-vaults now belong to the household, not a company with a status page. For a reader already running a home AI lab and a NAS, that's a Tuesday, not a burden; for a household without a member willing to own that upkeep, the managed tier (p17) is the honest recommendation, not a compromise.

THE WHOLE LADDER, ONE TABLE

CATEGORY	ENTRY	SWEET SPOT	CUSTOM / PRO
Hardware key	Titan · \$30	YubiKey 5C NFC · \$58	Nitrokey 3 / FIPS series
Password manager	Proton Pass · \$2/mo	Bitwarden Families · \$4/mo	Vaultwarden · self-hosted
Network appliance	Omada Fusion · \$170	Firewalla Gold SE · \$479	Protectli + OPNsense
Backup NAS	QNAP TS-464 · ~\$470	Synology DS925+ · ~\$650	DS1825+ / TS-h series
Cloud backup	Backblaze Personal · \$9/mo	Arq + Backblaze B2	Self-run offsite + B2
Remote access	Tailscale · free	Tailscale · free (100 dev.)	Headscale · self-hosted

Consolidated from pricing researched across p17–19, Aug 2026; verify current prices before purchase.

THE LAST TWELVE MONTHS, GRADED

- Yubico × OpenAI mandatory hardware passkeys (real, not hype).** Announced and made mandatory within five weeks — the strongest "genuinely changed something" signal in this book's gear research.
- OPNsense's rise over pfSense (real).** A licensing shift, not a marketing push, moved enthusiast default choice.
- KeePassXC's ANSSI certification + passkey support (real, incremental).** The free/offline option is no longer strictly a compromise pick — though it still lags 1Password/Bitwarden on passkey UX.
- 1Password and Bitwarden's 2026 price rises (a trend, not an event).** Subscription creep across the category makes the self-hosted tier relatively more attractive by the month.

CLOSING THIS DESK

Three pages, one honest total: a household can build the entire buy-once-cry-once ladder in this book — two hardware keys, a family password manager, a mid-tier network appliance, an immutable-snapshot NAS, a cloud backup subscription and Tailscale — for under US\$2,000 all-in, spread across purchases that each last years rather than one large outlay. That number is the real answer to "how much does taking this seriously cost," and it compares favourably with a single flagship watch or camera lens this reader's other hobbies might already justify.

SOURCES | Tailscale official homelab use-case documentation; Rack2Reality, Home Assistant + Tailscale remote-access walkthrough, 2026.

MENTORING, NOT MONITORING

The Family Desk

The parental-control app marketed to watch a child's every message left that same child's real-time location exposed to the whole internet for a year — the single strongest argument in this book for choosing conversation over surveillance software.

this story 

"**M**entoring is much more crucial than monitoring. Monitoring is optional, but mentoring really isn't," writes Devorah Heitner, author of *Growing Up in Public* — the clearest expert framing found for this exact age.¹ The American Academy of Pediatrics agrees in substance for this bracket specifically: research supports "autonomy-granting, active monitoring" over "controlling and restrictive monitoring," which the AAP directly associates with worse outcomes — devices in shared spaces rather than a bedroom at eleven, co-viewing rather than surveilling from a distance.² Troy Hunt, who built *Have I Been Pwned*, reviewed commercial kid-monitoring apps for his own household and found them "consistently poor, filled with fear-mongering at best and massive privacy violations at worst" — his conclusion: talk with kids and browse alongside them, because a

determined eleven-year-old outpaces most technical controls anyway.³

Both major platforms shipped real changes this year. Apple's June 2026 preview adds a simplified Child Account setup, flexible per-category Time Allowances, and an "Ask to Browse" Safari feature requiring parental approval before a first visit to a new site; Communication Safety — already default for under-18 accounts — is being expanded to flag violent imagery, not just nudity.⁴ Worth the honest caveat online-safety researchers have already raised: both Apple's and Google's systems remain largely opt-in, so the net only works where a family and the apps involved actually turn it on.⁵

1 yr

HOW LONG A PARENTAL-MONITORING APP'S EXPOSED DATABASE LEFT A CHILD'S REAL-TIME GPS LOCATION, PRIVATE MESSAGES AND IP ADDRESS PUBLICLY ACCESSIBLE BEFORE DISCOVERY⁶

THE SCAMS ACTUALLY TARGETING AN 11-YEAR-OLD

"Free Robux" and "free Nitro" generators are, without exception, credential-theft pages — Roblox's economy makes third-party Robux generation structurally impossible, and fake Discord gift links (anything outside [discord.gift](https://discord.com/gifts) or discord.com/gifts) harvest a login and immediately re-send the same scam to the victim's entire friends list.⁷ A pattern gaming-safety advisories describe as one of the most common ways a young teen loses an account: a stranger messages claiming the account was "reported," offering to connect the victim with a "Discord Mod" — who is the scammer, and who then asks for the password and the 2FA code directly. Singapore's own 2025 data shows the stakes are not abstract: under-19 victims made up 5.5 percent of the country's scam cases in the first half of the year, losing an average of S\$4,732 each.⁸ The single technical fix that closes most of this off: enable 2FA on the gaming/chat accounts themselves, not just the household's own logins.

THE SCEPTIC

Home settings only cover the risk a family can see. A nursery-school operator, Kido International, was breached by ransomware in September 2025, with attackers publishing ten children's names, photos and home addresses as extortion leverage before backlash forced a retraction.⁹ A smart toy maker, Miko, separately left children's AI-conversation transcripts exposed until US senators intervened in February 2026.¹⁰ Neither was preventable by anything on this page — device hygiene is necessary and still not sufficient once a child's data lives inside a school's or a toy maker's systems.

SOURCES 1 Devorah Heitner, devorahheitner.com; Tilt Parenting interview, Sept 2023. 2 American Academy of Pediatrics, Center of Excellence on Social Media and Youth Mental Health, "Balancing Online Safety and Independence: Parental Monitoring by Age." 3 Troy Hunt, "Sharenting, BYOD and Kids Online," troyhunt.com; Troy Hunt, Weekly Update 137. 4 Apple Newsroom, "Apple previews new child safety features," Jun 2026; Help Net Security, 9 Jun 2026. 5 understandtech.co.uk, Google Family Link 2026 guide; AppleInsider and TechRadar, expert commentary on opt-in limitations, Jun 2026. 6 Cybernews, "Parental control app KidSecurity data leak"; Android Headlines, 2024 (dated outside this book's window but still current in 2026 comparison journalism). 7 malwaretips.com, Roblox "Free Robux" scam analysis, 2026; Bitdefender HotForSecurity, Discord Nitro scam explainer. 8 Mothership.sg, citing SPF Mid-Year Scam and Cybercrime Brief 2025, Aug 2025. 9 The Register, "Ransomware gang publishes toddlers' images," 25 Sep 2025; Malwarebytes, "From threats to apology," Oct 2025. 10 NBC News, "AI toy maker exposed thousands of responses from kids," Feb 2026; Sen. Marsha Blackburn press release, Feb 2026.

THE MAP

The Community

A licensing change to a free firewall distribution moved more enthusiast opinion in six months than any vendor's marketing budget could — the community argues in public, and the argument is usually worth reading.

this story  

r/cybersecurity runs roughly 1.5 million members, posting close to eighteen times a day; **r/homelab** sits near 1.1 million, with about 226,000 new members in the past year alone — the router-and-firewall crowd, not the enterprise-pentest crowd.¹ **r/selfhosted** runs somewhere between 725,000 and 817,000 depending on which third-party tracker is counting (Reddit itself stopped publishing a public subscriber figure in September 2025, replacing it with "weekly visitors" instead — a small, real story about the platform reducing its own transparency). **r/HomeNetworking** sits near 500,000, and the broader **r/privacy** runs about 1.7 million.² The single most-asked recurring question across the homelab and networking clusters, per multiple 2026 comparison sites tracking the discourse, is simply "what firewall should I run" — and the answer has visibly shifted this year.

That shift has a specific, datable cause: Netgate pushed development toward a closed-source,

subscription-priced "pfSense Plus" — roughly US\$129 a year off Netgate's own hardware — while the free Community Edition slowed to a less frequent update cadence. Enthusiast consensus moved toward OPNsense as the new default, cited for its weekly security releases and lack of a paywall (p18).³ It is a genuinely useful case study in how a licensing decision, not a security flaw, reshapes what a whole community recommends.

~1.5M

R/CYBERSECURITY'S ESTIMATED MEMBERSHIP, 2026 — THIRD-PARTY TRACKER FIGURE, SINCE REDDIT STOPPED PUBLISHING SUBSCRIBER COUNTS IN SEPT 2025¹

A licensing decision, not a disclosed vulnerability, is what actually moved this year's enthusiast consensus on which firewall to run.

WHAT PRACTITIONERS ACTUALLY PRIORITISE AT HOME

Security researcher Daniel Miessler's own published home-network philosophy — deliberately "top-heavy," with the first few actions mattering far more than anything after — is the clearest, most attributable practitioner artifact found for this book: change every default password, use a password manager, patch everything, then consider a privacy-filtering DNS resolver. Only after that: enable 2FA on the highest-leverage accounts specifically (the primary email and the mobile carrier account — "the keys that open all doors" — before anything else), then segment IoT devices onto their own network.⁴ The honest finding behind this box: a specific, often-repeated magazine narrative — security professionals privately admitting a gap between what they sell clients and what they run at home — could not be substantiated with a real, attributable quote after a genuine search. What IS real and well-supported is a softer, still useful pattern: practitioners' actual home setups concentrate on a handful of high-leverage fundamentals rather than the maximalist gear stack marketed to enthusiasts.

SOURCES 1 MediaFast and ReddTrends, **r/cybersecurity** subscriber estimates, 2026; TheHiveIndex and GummySearch, **r/homelab** estimates. 2 RedPulse, GummySearch, TheHiveIndex, **r/selfhosted** estimate range; GummySearch, **r/HomeNetworking** and **r/privacy** estimates; Backlinko/Demandsage, Reddit subscriber-counter removal, Sept 2025. 3 DIYMediaServer, HomelabAddiction, WiredHaus, TechFuelHQ, OPNsense-vs-pfSense 2026 homelab comparisons. 4 Daniel Miessler, "A 3-Tiered Approach to Securing Your Home Network," danielmiessler.com.

For a household that wants to keep learning past this book, the channels genuinely covering home and consumer security — verified active in 2026, not enterprise pentesting content — split into distinct lanes worth knowing apart. **Techlore**, which absorbed its former news show as "Techlore Surveillance Report," pairs practical tool guidance with ongoing privacy-news coverage. **Naomi Brockwell TV** runs interview-driven coverage bridging consumer tooling with actual privacy legislation. **The PC Security Channel** is the one to watch specifically for the antivirus question this book opened with (p5) — it runs live malware-versus-AV demonstrations rather than talking about them. **All Things Secured** is the closest to a pure how-to channel: password managers, VPN setup, locking down social accounts, aimed at a beginner rather than an enthusiast. **NetworkChuck** is the largest and most general of the group — a gateway channel for the segmentation-and-firewall crowd this section describes.¹

One structural note worth printing plainly, since it explains why so much VPN and antivirus coverage

online reads the way it does: **Privacy Guides**, the nonprofit behind privacyguides.org and its own YouTube channel, was founded in 2021 specifically because the commercial VPN and privacy-tool review space was judged too compromised by affiliate-commission incentives to trust — a structural conflict of interest this book's own Sceptic desk (p23) returns to directly.²

ALSO WORTH KNOWING

r/PrivacyGuides and **r/HomeNetworking** — smaller, more focused communities; no reliable current subscriber figure was confirmable for the former this session.

The Register's forums — where practitioners trade real disaster-recovery stories (p15), including the backup-vendor-deletes-its-own-forum irony cited on this book's Last Line desk.

CISO Series' Reddit AMA series — recurring, named-practitioner Q&As on [r/cybersecurity](https://www.reddit.com/r/cybersecurity), though mostly organisational rather than home-focused.

r/selfhosted — the Vaultwarden/Headscale crowd from p19; a July 2026 community-written piece on the sub's own culture shift signals a live internal debate about it growing more product-review-driven than DIY.

THE SCEPTIC

A large, active community is not the same claim as a trustworthy one. The same searches that surfaced these communities also surfaced their honest limits: Reddit's own subscriber-count removal makes even basic size claims a moving target between trackers, and this book could not verify a single first-hand practitioner "confession" comparing client advice to home practice — a narrative frame that circulates as received wisdom in security-community folklore without, on the evidence gathered here, much backing it up.

A SMALL GLOSSARY

AITM (ADVERSARY-IN-THE-MIDDLE)

A phishing proxy that relays a real login flow both directions, capturing the password, the MFA code, and the session cookie issued after — the mechanism behind most 2025–26 MFA bypasses (p11).

CLICKFIX

A fake CAPTCHA or error page that tricks a user into pasting a malicious command into Run or Terminal themselves (p3).

IMMUTABLE SNAPSHOT

A NAS backup state that cannot be deleted or encrypted, even by a compromised admin account, until its retention window expires (p15).

PASKEY

A cryptographic credential bound to a website's real domain — a phishing proxy cannot complete the handshake even with a perfect fake page (p11).

VLAN SEGMENTATION

Splitting a home network into isolated zones so a compromised smart device can't reach a laptop or NAS (p13).

SOURCES 1 Security Boulevard, "top cybersecurity YouTube channels 2026" roundup; individual channel verification via YouTube search, Aug 2026. 2 Privacy Guides, "From Content Creator to Policymaker" interview, privacyguides.org, 16 May 2026.

THE HARDEST CROSS-EXAMINATION

The Sceptic

The company selling identity-theft protection got breached by the exact social-engineering attack it exists to protect customers from — the single fact this desk keeps coming back to.

this story 

I dentity-theft-protection subscriptions — LifeLock and its peers — do not prevent identity theft. By design, they are after-the-fact alert systems: monitoring for fraudulent activity already under way, then offering recovery assistance once it's happened.¹ The irony writes itself this year: in March 2026, Aura — an identity-theft-protection vendor — disclosed that attackers used a vishing (voice phishing) attack against an employee's Okta-linked account to reach roughly 900,000 marketing records. Aura says no Social Security numbers, financial data or passwords from its core monitoring product were exposed, and the access window was about an hour before revocation — genuinely limited as breaches go, and still the sharpest available illustration that a company selling protection from social engineering is not thereby immune to it.²

VPN marketing is the second target this desk takes seriously, and the critique comes from an unusually credible source: Have I Been Pwned's Troy Hunt has publicly called commercial VPN marketing claims "snake oil" — and was later hired as a paid advisor specifically to help one provider, NordVPN, pull its own marketing back from claims he judged

unreasonable.³ The technical case underneath the skepticism is simple and holds up: a VPN encrypts network traffic and can mask an IP address. It does not scan for malware, does not stop phishing (which exploits judgment, not routing), and does not block tracking cookies. Krebs on Security has separately documented how VPN affiliate-commission programmes incentivise manufactured reviews across the entire comparison-site ecosystem this book's own readers are likely to consult — a structural reason to discount most "best VPN" roundups on sight.⁴

900,000

RECORDS EXPOSED IN AURA'S OWN MARCH 2026 BREACH — AN IDENTITY-THEFT-PROTECTION VENDOR, HIT BY THE EXACT SOCIAL-ENGINEERING VECTOR IT SELLS PROTECTION FROM²

The tool marketed to catch identity theft after it happens is not the same purchase as a tool that prevents it.

THE BELIEVER'S CASE, FAIRLY STATED

None of this is a case against every product in this book. AV-TEST and AV-Comparatives' own 2026 rounds are real, independently-run evaluations, not marketing (p5); Firewalla and UniFi's own reviewers, cited on their own product pages, genuinely do document real capability, not just price. The Sceptic desk's target is narrower and more specific than "buy nothing": paid antivirus beyond a well-configured Defender, identity-theft-monitoring subscriptions, VPN-as-a-security-purchase, and privacy-invasive smart cameras — a specific, bounded list, not a case against the whole category.⁵

THE CAMERA IN THE DOORBELL

Ring received the Electronic Frontier Foundation's "Worst in Show" award at CES 2026, with EFF's Cindy Cohn criticising the company for "doubling down on privacy invasion and supporting the misconception that more surveillance always makes us safer."⁶ Ring shared footage from over 2,000 accounts without a warrant before a 2023 policy change; a planned data-sharing partnership with law-enforcement analytics firm Flock Safety, announced October 2025, was scrapped by Amazon in February 2026 after public pressure. And the plainest home-security fundamental of all is still the most-skipped one: over 51 percent of home users have never updated their router's firmware, meaning the gap between "owns security gear" and "is actually secured" often has nothing to do with which gear was purchased.⁷

SOURCES 1 Aura's own comparison page, "Is LifeLock Worth It?"; Clark.com identity-protection analysis. 2 Wikipedia, "Aura data breach"; IdentityIQ and Tom's Guide, Mar 2026 reporting. 3 Troy Hunt, "Padlocks, Phishing and Privacy: The Value Proposition of a VPN," troyhunt.com; Tom's Guide, NordVPN/Troy Hunt partnership coverage. 4 Krebs on Security, "Why Your VPN May Not Be As Secure As It Claims," 2024; Zscaler and Windows Report, VPN-limitations explainers. 5 Editorial synthesis, this edition. 6 EFF, "No One... Will Be Safer in Ring's Surveillance Nightmare," Feb 2026; CES2026 "Worst in Show" coverage. 7 Krishnamoorthi press release, Ring/Flock Safety scrutiny; Security Boulevard, Jul 2025; Vecosys, "15 Essential Home Network Security Settings," router-firmware-neglect statistic.

STILL MOVING

The Fresh-Peg Sweep

A malicious ComfyUI node disguised as a 4K upscaler ran for three months, on the official registry, before anyone caught it — the single incident in this book aimed most precisely at a home AI lab like this one.

this story  

The supply-chain incident most precisely aimed at this reader's own setup is fully dated and fully documented on the official ComfyUI GitHub repository, not a secondary summary. In October 2025, a user published two malicious custom nodes — `upscaler-4k` and `lonemilk-upscalernew-4k` — to the Comfy Registry, disguised as an image-enhancement tool. A near-identical repository appeared under a different name in January 2026 and was published to the registry on 9 January; a Discord user flagged installable malware the day before, and the issue was formally filed 10 January.¹ The mechanism: the node's install script silently ran `pip install` requests via subprocess, then copied itself into `AppData\Roaming` as `DisplayUpdater.exe` with hidden file attributes, downloaded a PyArmor-protected payload from two command-and-control domains, and deployed a modular Golang infostealer — Akira Stealer — that harvested browser data, cryptocurrency wallets and Discord tokens. Combined installs across the malicious nodes before takedown: 779.²

It wasn't isolated. In April 2026, more than a thousand internet-exposed ComfyUI instances were roped into a cryptomining and proxy botnet through internet-wide scanning that exploited a known misconfiguration — running ComfyUI's web interface

bound to all network interfaces, a routine choice for reaching it from another device on the LAN, exactly the setup a home AI lab is likely to run.³ ComfyUI's own maintainers responded with real, structural fixes rather than a statement: subprocess-based `pip install` calls from within a node are now banned under Comfy Registry policy, and a remote kill-switch lets maintainers disable a flagged node across every installation without waiting for a full ComfyUI update.⁴ Hugging Face had its own version of this problem in 2025 — researchers found ML models using a "broken pickle" trick, compressing a file with 7-Zip instead of the expected format specifically to evade the Picklescan safety scanner while still partially executing a reverse shell on load.⁵

779

CONFIRMED INSTALLS OF A MALICIOUS "4K UPSCALER" COMFYUI NODE, PUBLISHED TO THE OFFICIAL REGISTRY, BEFORE REMOVAL²

Never expose a ComfyUI, Jupyter, or local-LLM web interface to the internet without something in front of it — the same lesson as the NAS admin panel, one desk later.

A WORM THAT PUBLISHES ITS OWN SEQUEL

The npm ecosystem's defining 2025–26 incident is Shai-Hulud, a self-replicating worm first detected September 2025: it compromises a package, uses the stolen maintainer access to publish poisoned versions of that same maintainer's OTHER popular packages, and repeats — propagating without a command-and-control connection at all. A November 2025 second wave, "Shai-Hulud 2.0," backdoored 796 unique packages totalling over twenty million weekly downloads and exfiltrated credentials from more than 500 GitHub users. It kept mutating through 2026, including a February variant reported to specifically hijack CI workflows and poison AI toolchains.⁶ For anyone running `npm install` on a dev box regularly — this household's WSL2 environment (p7) included — Datadog's own remediation guidance is blunt: rotating a compromised token isn't enough; check for persistence via self-hosted GitHub Actions runners and review recent repository creations for anomalies.

SOURCES 1 GitHub, Comfy-Org/ComfyUI, Issue #11791, directly cited. 2 Same source. 3 The Hacker News, "Over 1,000 Exposed ComfyUI Instances," Apr 2026; Censys, ComfyUI cryptomining-botnet research. 4 blog.comfy.org, "ComfyUI 2025 Jan Security Update"; docs.comfy.org, registry standards. 5 The Hacker News, "Malicious ML Models Found on Hugging Face," Feb 2025; JFrog, "Data Scientists Targeted by Malicious Hugging Face ML Models." 6 CISA alert, "Widespread Supply Chain Compromise Impacting npm Ecosystem," 23 Sep 2025; securitylabs.datadoghq.com, "Shai-Hulud 2.0," Nov–Dec 2025, directly cited.

The Python ecosystem had its own fully-documented version, directly relevant to any AI tooling installed via `pip`. On 24 March 2026, versions of LiteLLM — a widely used LLM-serving proxy — were compromised on PyPI: one release injected malicious code executed on import, the next shipped a `.pth` file that ran arbitrary code at Python interpreter STARTUP, meaning it would fire in nearly any environment that loaded Python at all, not only one actively using LiteLLM. Days later, Telnyx packages were backdoored via a payload hidden inside a WAV audio file's frame data. PyPI's own incident report is explicit that reverting the package version alone does not remediate an infection — full credential rotation and a rebuild from known-good images are required.¹ PyTorch Lightning, a common training-loop library, was separately compromised on PyPI in April 2026.²

VS Code's own extension marketplace had a rough year too: malicious-extension detections nearly quadrupled from 27 in 2024 to 105 across January–

October 2025, and researchers found more than 100 extensions — a combined install base over 125 million — that had leaked their own publisher access tokens, meaning an attacker could push a malicious auto-update to the entire install base without any user action at all, since VS Code updates extensions automatically by default.³ And the pattern connecting nearly everything on this page to the ClickFix technique from page three: Bitdefender documented a March 2026 Google Ads campaign impersonating Anthropic's own Claude Code branding, complete with a fake "Sponsored" badge, redirecting to a spoofed documentation page and using the exact copy-paste-into-Terminal trick to deliver malware on both Windows and macOS — aimed, almost too precisely, at the AI-forward developer this book is written for.⁴

27 → 105

MALICIOUS VS CODE EXTENSIONS DETECTED, 2024 VS. JAN-OCT 2025 — A NEAR-QUADRUPLING IN A SINGLE YEAR³

THIS BOOK'S SUPPLY-CHAIN INCIDENTS, DATED

INCIDENT	ECOSYSTEM	DATE
ComfyUI "4K upscaler" node	AI/ComfyUI	Oct 2025 – Jan 2026
Hugging Face pickle backdoor	AI/ML models	Feb 2025
Shai-Hulud / Shai-Hulud 2.0	npm	Sep–Dec 2025
LiteLLM / Telnyx	PyPI	Mar 2026
PyTorch Lightning	PyPI	Apr 2026
VS Code token-leak wave	VS Code Marketplace	through Oct 2025
Fake "Claude Code" ads	Windows + macOS	Mar 2026

HELD FOR THE NEXT EDITION

An AI agent publishing malicious code, autonomously. One report describes an AI coding agent publishing a malicious package to PyPI, run by real systems, without a human attacker directing each step. Genuinely new category of risk if confirmed — this book could not independently verify the claim this session and prints it as unconfirmed rather than as fact.

Exact August 2026 Patch Tuesday zero-day count. Coverage split between "one actively exploited" and "three total, including publicly-disclosed-but-unexploited" — reconciled where possible on p6, flagged where not.

THE SCEPTIC

Every incident on these two pages shares a mitigation this book has now repeated four times: read an install script before running it, don't expose a development or AI tool's web interface to the raw internet, and treat any curl-to-shell or freshly-copied terminal command as hostile until proven otherwise. None of it required a zero-day. The supply chain broke because a maintainer's account was compromised, a registry didn't check what it was hosting, or a user pasted a command — the same three failure modes as every other desk in this book, replayed in a different ecosystem.

SOURCES 1 [blog.pypi.org, "Incident Report: LiteLLM/Telnyx Supply Chain Attack,"](https://blog.pypi.org/Incident-Report-LiteLLM-Telnyx-Supply-Chain-Attack/) 2 Apr 2026; [securitylabs.datadoghq.com, LiteLLM/TeamPCP campaign,](https://securitylabs.datadoghq.com/LiteLLM/TeamPCP-campaign/) directly cited. 2 Sonatype, "Malicious PyTorch Lightning Packages Found on PyPI," Apr 2026. 3 ReversingLabs, "VS Code Marketplace malicious-extension data, 2025; The Hacker News, "Over 100 VS Code Extensions Exposed Developers to Hidden Supply Chain Risks," Oct 2025. 4 Bitdefender Labs, "fake Claude Code" Google Ads campaign; MI-3 and SecurityOnline corroborating coverage, ~Mar 2026.

THE UNDERCURRENT

The Robocall Drill

A government dialling its own citizens with fake scam calls, on purpose, folded into the same doctrine built for war and pandemic — inside the country that just discovered its scam losses are falling and its median victim is losing more anyway.

this story  

On 1 March 2026, phones across Singapore began ringing with scam calls that weren't scams. The Cyber Security Agency of Singapore, with the Ministry of Home Affairs, had begun a six-month pilot — the National Simulated Scams Exercise, running through 31 August — dialling registered participants with robocalls built to mimic real scammer tactics, focused specifically on Government Official Impersonation Scams, which CSA itself flags as "a key scam type of concern."¹ Malaysia's *The Star* and the *New Straits Times* both reported the same striking framing on the same day the exercise opened for registration: this is not a standalone consumer-education campaign. It has been folded explicitly into Singapore's Total Defence doctrine — the same conceptual architecture built, since the Cold War era, around military, civil, economic, social and (more recently) digital resilience — as part of "Exercise SG Ready 2026."² Malay Mail's own headline called it a "Robocall Ambush Drill." That is not spin. It is close to an accurate description of what a state civil-defence exercise against fraud actually looks like when the threat is psychological rather than physical.

The doctrine shift makes more sense against the numbers underneath it, and the numbers themselves resist a simple headline. Singapore's total scam losses actually FELL — from S\$1.1 billion in 2024 to S\$913.1

million in 2025, a 27.6 percent drop, the first recorded decrease since police began reporting scam figures as a distinct category in 2023.³ Read only that far, and the honest, welcome story is that Singapore's scam-fighting apparatus is working. Read one line further and the picture complicates: median loss per case ROSE over the same period, from S\$1,389 to S\$1,644 — fewer victims, each one bled harder. And one category moved against the entire trend: government-official impersonation scams surged 123.6 percent year over year, even as the aggregate fell.⁴ The state is winning the volume war and losing, specifically, the trust war — and a civil-defence drill against exactly that category is the government's own answer to which fight it has decided to prioritise.

+123.6%

YEAR-OVER-YEAR RISE IN GOVERNMENT-OFFICIAL
IMPERSONATION SCAMS IN SINGAPORE, EVEN AS TOTAL
SCAM LOSSES FELL⁴

The state is winning the volume war and losing the trust war — and a civil-defence drill is its answer to which fight it has chosen to prioritise.

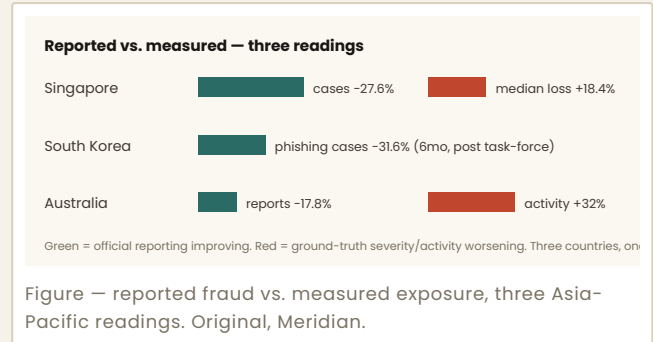
THE FOOTAGE POLICE RELEASED ON PURPOSE

The single most citable artifact behind this year's escalation is a piece of evidence Singapore's own police force chose to make public rather than keep in a case file: on 16 May 2026, SPF released footage from a Zoom video conference used in a scam impersonating senior government officials — including, the advisory specifies, the Secretary to the Cabinet — targeting business professionals with prior genuine government contact, luring them into fake virtual "meetings" framed as involving the President and Ministers themselves.⁵ Releasing the actual deepfake footage as a public warning is a deliberate escalation in itself: it treats the fabricated video not as evidence to prosecute quietly, but as the public-education artifact the whole civil-defence framing depends on — you cannot drill a population against a threat you won't show them.

SOURCES 1 CSA and MHA joint press release, "National Simulated Scams Exercise as Part of Exercise SG Ready 2026," csa.gov.sg. 2 *The Star* (Malaysia), 2 Feb 2026; *New Straits Times*, Feb 2026. 3 SPF Police Life, "Scams and Cybercrime Fell by Almost a Quarter in 2025," Feb 2026; SPF Annual Scam and Cybercrime Brief 2025. 4 Same SPF source, median-loss and GOIS-surge figures. 5 Singapore Police Force, "Footage From Zoom Video Conference Involving Impersonation Of Senior Government Officials," 16 May 2026.

Singapore is not alone in treating fraud as a state-defence problem rather than a consumer-protection one — the region is running three genuinely different versions of the same instinct, worth reading side by side. South Korea shifted the LIABILITY, not just the messaging: a police-Naver collaboration dubbed "Triple Barrier" against phishing, paired with new rules raising bank executives' personal liability for phishing losses, produced a documented 31.6 percent drop in voice-phishing cases within six months of the joint task force's launch — institutions, not individual victims, now carry more of the cost of failure.¹ India is fighting a regulatory turf war instead: telecom regulator TRAI was intercepting 27.7 crore — 277 million — unsolicited calls and messages a day by May 2026, rolling out a verified Calling Name Presentation system by March, while Truecaller's own CEO has publicly clashed with TRAI, arguing the regulator's rules made India's spam problem worse, not better — a genuine fight over who controls anti-fraud infrastructure, not merely how to fund it.²

Australia supplies the most unsettling comparison, because its official reporting and its measured reality are pulling in opposite directions: Scamwatch reports were down 17.8 percent year over year in the first quarter of 2026, yet cybersecurity firm Gen's own H1 2026 threat telemetry shows overall scam ACTIVITY up 32 percent, with gambling-scam activity up 927 percent and remote-access-trojan activity up 104 percent.³ That is Singapore's own falling-cases-rising-severity pattern, generalised: official reporting and ground-truth exposure are quietly diverging almost everywhere this book looked, which is itself the region's real, under-covered story — not any single country's fraud total.



Official reporting and ground-truth exposure are quietly diverging almost everywhere this desk looked — that gap is the region's real story, not any single country's total.

India's fight is the clearest illustration of infrastructure, not awareness, being the actual battleground. The telecom regulator TRAI rolled out a verified Calling Name Presentation system by March 2026, powered by KYC databases rather than a user-submitted directory — and was, by its own numbers, already intercepting 277 million unsolicited calls and messages a day before that rollout finished. Truecaller's public clash with the regulator over whose rules actually reduce spam is the same argument Singapore, Korea and Australia are each having in their own institutional language: who owns the infrastructure that decides which call gets through is now a more consequential policy fight than any single awareness campaign.²

4

DISTINCT NATIONAL APPROACHES TO FRAUD-AS-STATE-DEFENCE FOUND IN THIS BOOK'S RESEARCH — SINGAPORE'S CIVIL-DEFENCE DRILLS, KOREA'S INSTITUTIONAL-LIABILITY SHIFT, INDIA'S INFRASTRUCTURE FIGHT, AUSTRALIA'S TELEMETRY GAP¹

WHAT THIS BOOK COULD NOT CONFIRM

In the interest of the same honesty standard applied throughout this book: a widely-repeated Singapore figure — "\$\$11 billion lost to scams in 2024" — appears in at least one regional headline and conflicts sharply with the Singapore Police Force's own reported \$S\$1.1 billion figure for the same year. This book uses the SPF's own primary number and flags the larger figure as unverified rather than printing it.⁴ Direct confirmation that no major Western outlet has yet run a feature specifically on the National Simulated Scams Exercise could not be completed with certainty this session — every source located was Singaporean or Malaysian regional press, which is reasonable circumstantial evidence, not proof.

SOURCES 1 Seoul Economic Daily, "Police, Naver Build Triple Barrier to Combat Phishing Fraud," 24 Feb 2026, and "Voice Phishing Cases Drop 31.6 Percent in Six Months," 29 Mar 2026. 2 News4Hackers, TRAI daily-spam-blocking figures, May 2026; TechCrunch, "Truecaller Clashes With India's Telecom Regulator," 8 Jul 2026. 3 The Post Sydney, citing Gen H1 2026 threat report and Scamwatch Q1 2026 data. 4 SPF Annual Scam and Cybercrime Brief 2025 (primary figure used); Deccan Herald headline citing \$S\$11B (unverified, flagged, not used).

THE LAST WORD

Twenty-six pages ago this book opened with Bruce Schneier's line about process, not product, and it holds up as the honest closing argument too. Nothing in here is a single purchase that finishes the job — not the hardware key, not the immutable NAS snapshot, not the segmented VLAN a Matter household will fight with for a weekend. The process is the same six habits repeated in twelve different rooms of the house: patch promptly, distrust a pasted command, keep one backup nobody can touch, use a key instead of a code, watch the router nobody thinks about, and talk to the eleven-year-old instead of just watching her. Singapore's own government reached the same conclusion at civil-defence scale — the drill matters more than any single tool it's testing for.

FULL SOURCE LIST

Verizon Data Breach Investigations Report 2025/2026 (verizon.com) · Microsoft Digital Defense Report 2025 · Microsoft Security Blog · Microsoft Security Response Center (MSRC) · CISA (cisa.gov, KEV catalog, encrypted-DNS guidance) · NIST SP 800-63B · FIDO Alliance, "State of Passkeys 2026" · AV-TEST · AV-Comparatives · The Hacker News · BleepingComputer · SecurityWeek · Security Affairs · Malwarebytes · Bitdefender Labs / HotForSecurity · Trend Micro Research · Unit 42 (Palo Alto Networks) · SentinelOne / SentinelLabs · Krebs on Security · Troy Hunt (troyhunt.com) · Objective-See Foundation · Apple Support & Apple Newsroom · Six Colors · MacRumors · 9to5Mac · AppleInsider · MacTech · Jamf Threat Labs · Help Net Security · GitHub (Comfy-Org/ComfyUI, microsoft/WSL, teori-io/copy-fail-CVE-2026-31431) · Datadog Security Labs (securitylabs.datadoghq.com) · PyPI blog (blog.pypi.org) · ReversingLabs · Sonatype · CVE/NVD entries and vendor advisories (Synology, QNAP, TP-Link, Netgear, ASUS) · VulnCheck, "2026 State of Exploitation" · The Register · TechRadar Pro · Windows Forum · Phoronix ·

Docker Docs · Daniel Miessler (danielmiessler.com) · EFF (eff.org) · Electronic Frontier Foundation CES2026 coverage · Firewalla, Ubiquiti/UniFi, TP-Link Omada, Protectli official product pages · Yubico official press releases and store · 1Password, Bitwarden, Proton, KeePassXC, Vaultwarden official pages · Tailscale documentation · Backblaze, iDrive, Arq Backup official pricing · Devorah Heitner (devorahheitner.com) · American Academy of Pediatrics · Common Sense Media · Pew Research Center · Google Family Link / Family Guide to Online Safety 2026 · Cybernews · NBC News · Sen. Marsha Blackburn press release · Wikipedia (Aura data breach, Kido International cyberattack) · Singapore Police Force (police.gov.sg advisories and Annual/Mid-Year Scam and Cybercrime Briefs) · Cyber Security Agency of Singapore (csa.gov.sg) · The Star (Malaysia) · New Straits Times · Malay Mail · Mothership.sg · Seoul Economic Daily · TechCrunch · The Post Sydney · MERIDIAN No. 61 (daily), reader feedback log, 14 Aug 2026 01:10 UTC.